

Introduction and Basics

Foundations of Cybersecurity

Luca Caviglione

Institute for Applied Mathematics and Information Technologies

National Research Council of Italy

luca.caviglione@cnr.it

Outline

- Why a cybersecurity course?
- The Cyber Kill Chain
- MITRE ATT&CK
- Attack Surface
- Attack Tree
- Attack Surface Reduction
- Possible Vulnerabilities
- The Human Element
- Wrap Up



Why a Cybersecurity Course?



Source: World Economic Forum – Global Risks Report 2024 (data collected from over 11,000 business leaders in 113 economies).



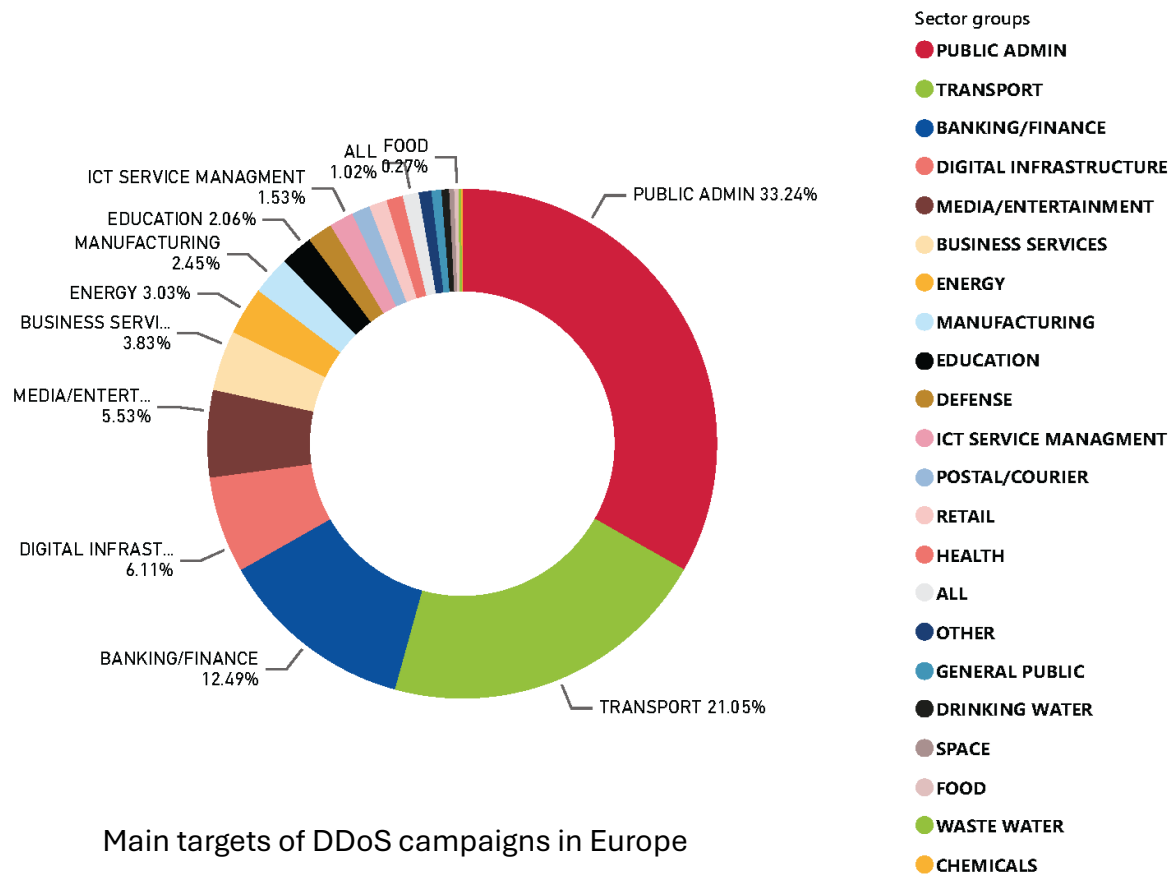
Why a Cybersecurity Course?



Source: World Economic Forum – Global Risks Report 2025 (data collected from over 11,000 business leaders in 121 economies).



Why a Cybersecurity Course?



As an example, Distributed Denial of Services are increasing in frequency, size, and complexity.

Some major facts:

Microsoft reported an average of 1,700 DDoS attacks per day, totaling 13 million attacks globally in 2023.

Gcore reported more than a 100% increase in peak attack volumes over the past three years, i.e., from 300 Gbps in 2021 to 1.6 Tbps in 2023.

Cloudflare reported thousands of massive HTTP DDoS attacks in Q3 2023, many exceeding 100M rps. The largest hitting was 200M rps, which is 8 times the 2022 record. The largest L3/L4 attack peaked at 2.6 Tbps and was a UDP flood launched by a Mirai-like botnet.

Source: ENISA Threat Landscape 2024 (July 2023 – June 2024).



Why a Cybersecurity Course?

Public administration is the most targeted sector with a significant increase in DDoS by hacktivists.

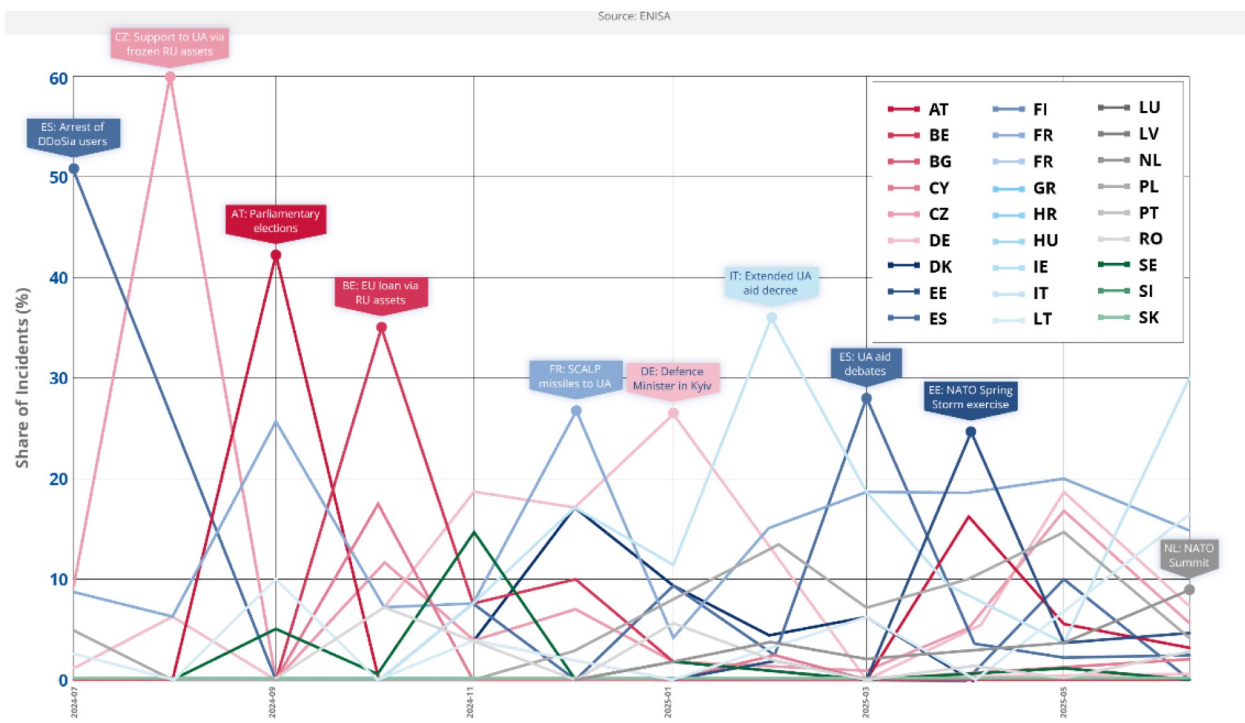
Some **major facts**:

Highest number of incidents are against public administrations of France, Italy, Germany, Spain and Poland.

Websites of entities like LEAs, defense, military, and diplomatic bodies are the primary targets.

Events such as takedowns and arrests, electoral processes or other high-visibility events are the main triggers.

Analysts reported that main motivations are related to Russia-Ukraine and Israel-Hamas conflicts, as well as societal issues like EU migration policies, LGBTQ+ legislation, or potential anti-religious stances.

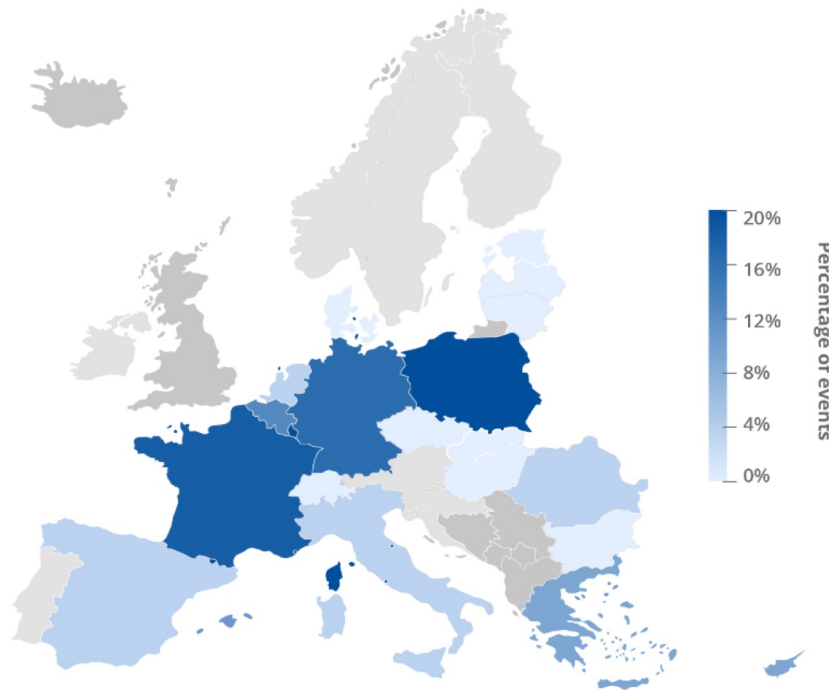


Contextualized DDoS campaigns in Europe against the Public Administration

Source: ENISA Threat Landscape 2025 (July 2024 – June 2025).



Why a Cybersecurity Course?



Russia-nexus intrusion sets

Source: ENISA Threat Landscape 2025 (July 2024 – June 2025).

The nature and geographical placement of targets partially relate to Europe supporting Ukraine.

Some **major facts**:

Focus of attack against governmental/diplomatic entities, defense and digital infrastructures.

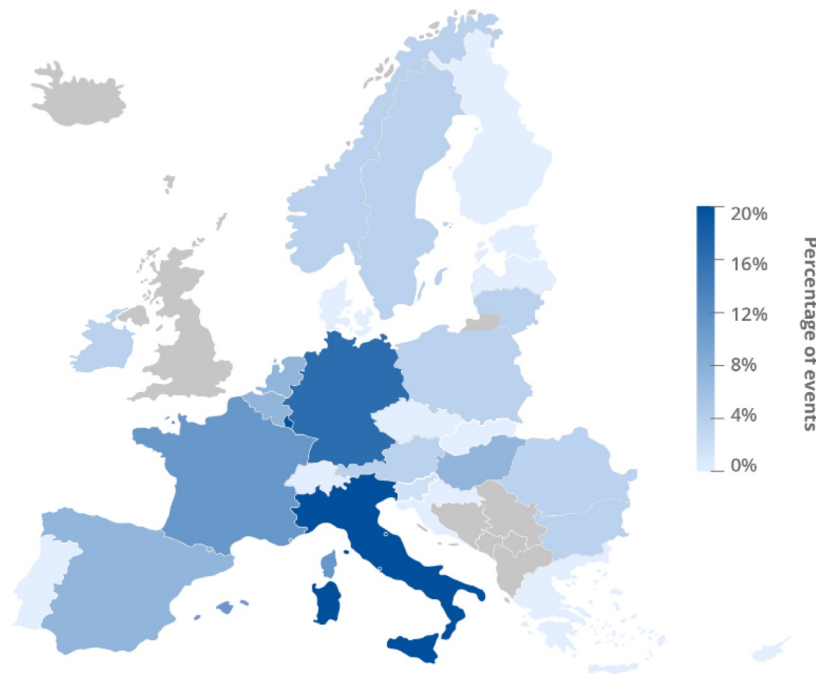
Notable activities are spearphishing espionage campaigns, mainly on transport, defense, logistics, telecom, embassies and political parties.

Relevant actors are state-linked threat groups like APT28, APT29, Turla, and Sandworm specialized in cyberespionage or destructive cyber operations.

An **Advanced Persistent Threat (APT)** is a well-resourced and funded threat actor conducting targeted, sophisticated, and prolonged cyber operations to achieve strategic objectives.



Why a Cybersecurity Course?



China-nexus intrusion sets

Targets are diplomatic entities, aviation/maritime industries, telecom, NGOs and human rights advocacy groups.

Some **major facts**:

Consistent cyberespionage campaigns against Italy, Germany, France and Belgium.

Emerging activities against food manufacturing and agricultural research industries.

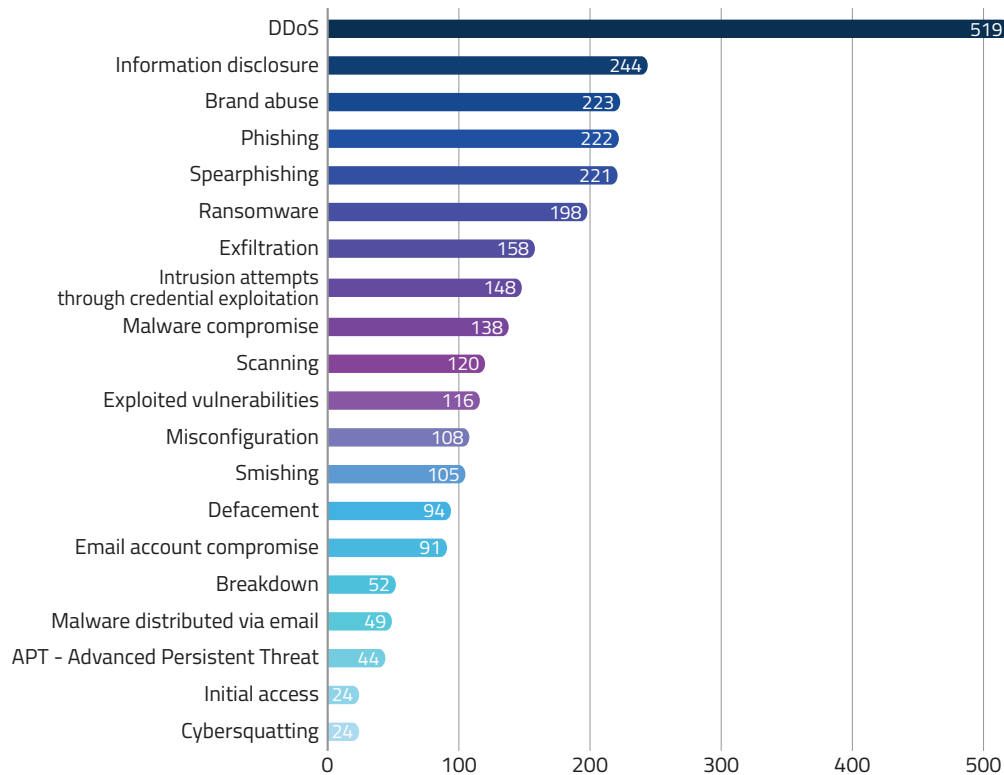
Attack drivers are data collection and intellectual property theft, narrative control and monitoring of dissident or diaspora networks.

Relevant actors are UNC522, Mustang Panda, APT4, Flax Typhoon, and Salt Typhoon specialized in edge-device exploitation, government espionage, and stealthy persistence.

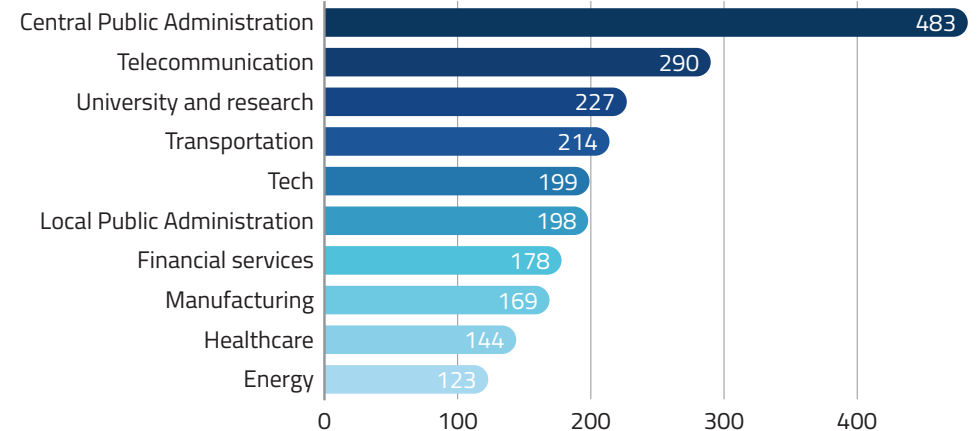
Source: ENISA Threat Landscape 2025 (July 2024 – June 2025).



Why a Cybersecurity Course?



Top 20 handled cyber events

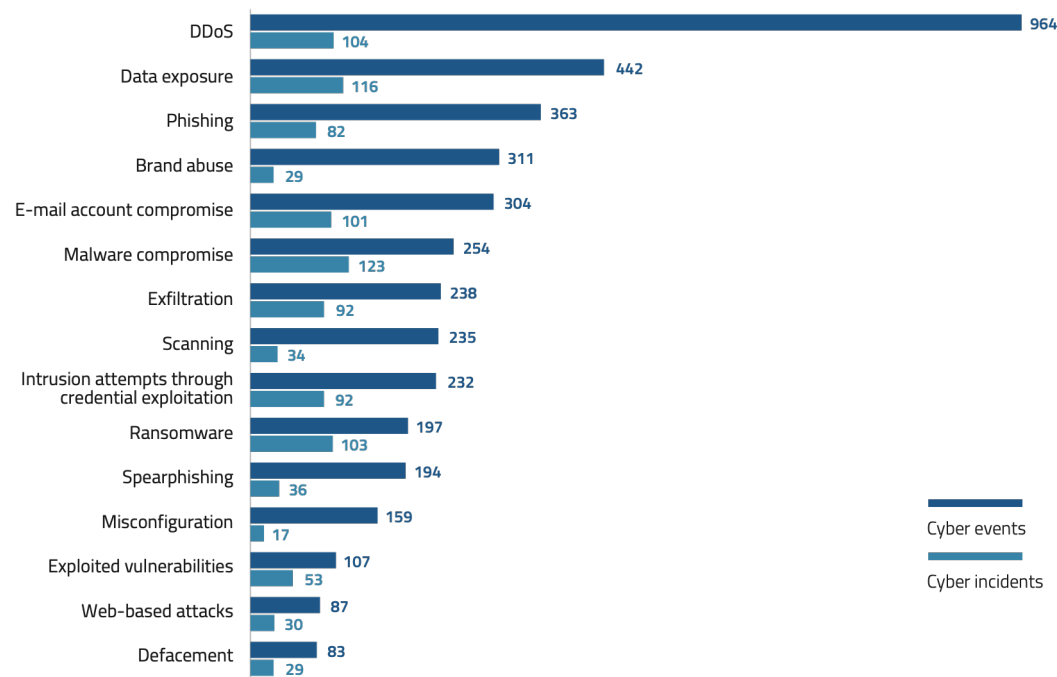


Top 10 economic sectors of victims

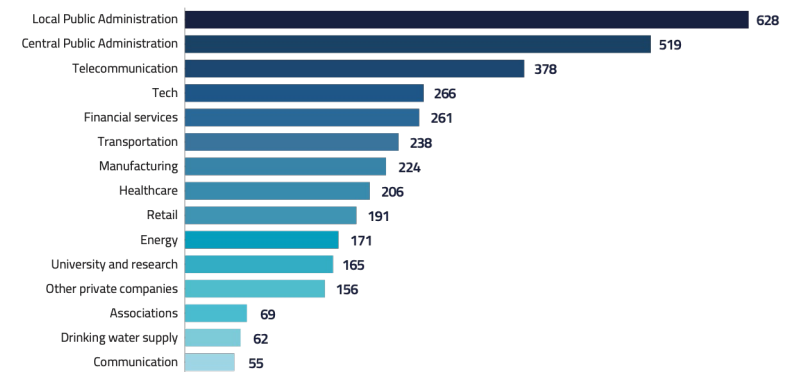
Source: ACN 2024 Year in Review.



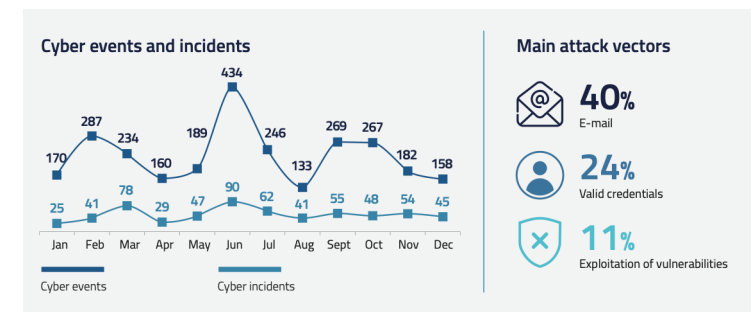
Why a Cybersecurity Course?



Top 15 handled cyber events and incidents



Top 15 economic sectors of victims



Distributions of incidents and attack vectors

Source: ACN 2025 Year in Review.

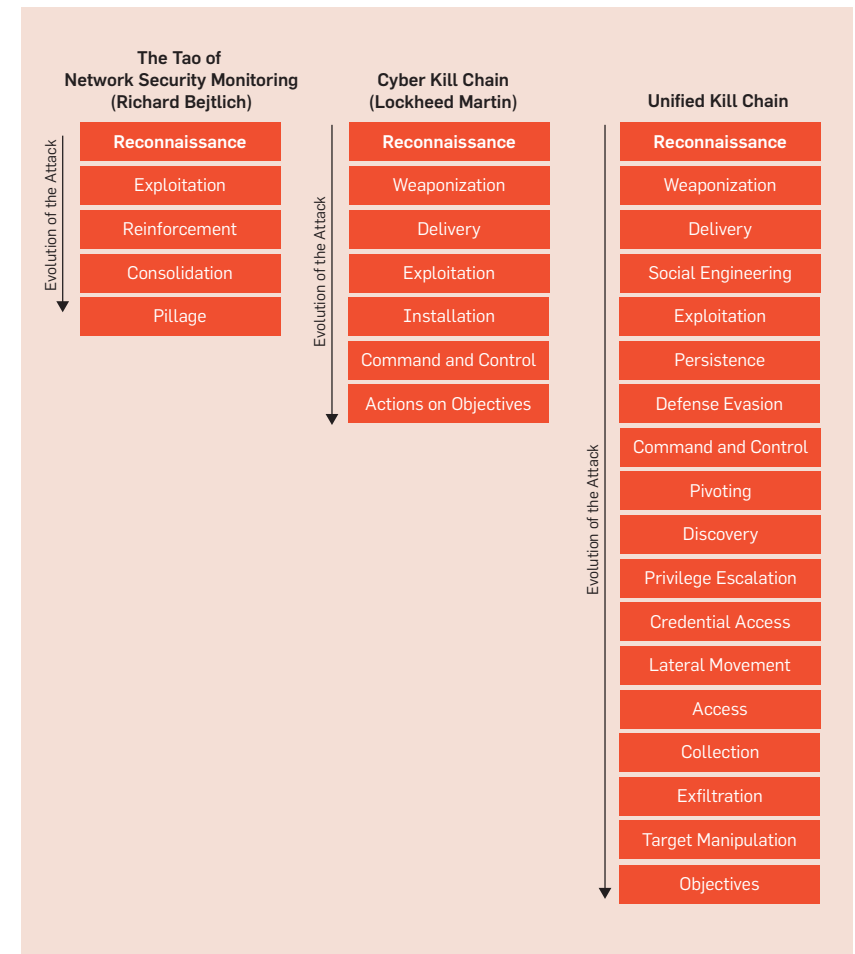
Why a Cybersecurity Course?

February 2023	April 2023	February 2024	July 2024	December 2024	February 2025
Hackers took down the Italian Agenzia delle Entrate website and sent phishing emails with a fake login page mimicking the official site.	Mandiant linked a 3CX Desktop App supply chain attack to North Korean hackers. It was the first case they found where a past supply chain vulnerability was reused in a new attack.	Starting in 2023, Russian hackers targeted embassies in Georgia, Poland, Ukraine, and Iran, using a webmail bug to install malware and gather political and military intelligence.	A faulty CrowdStrike update for Microsoft Windows caused a global IT outage, affecting 8.5 million machines and disrupting airlines and hospitals. Fortune 500 companies lost an estimated \$5.4 billion.	Russian hackers launched over 85,000 cyberattacks on Romania's election systems, leaking credentials online . The attacks occurred around the presidential vote and continued through election day.	North Korean hackers stole \$1.5 billion in Ethereum from ByBit by exploiting third-party wallet software . They laundered \$160 million within 48 hours, marking the largest crypto heist ever.

Source: Center for Strategic & International Studies – Significant Cyber Incidents since 2006.

The Cyber Kill Chain®

- An attack can be decomposed into some general and recurrent phases.
- Different models:
 - **Tao of Network Security Monitoring** subdivides the attacks into **five** stages
 - **Cyber Kill Chain** subdivides the attack into **seven** stages
 - **Unified Kill Chain** subdivides the attack into **eighteen** stages.
- The Cyber Kill Chain framework:
 - is the most used
 - subject to various critics
 - used as a reference and adapted.

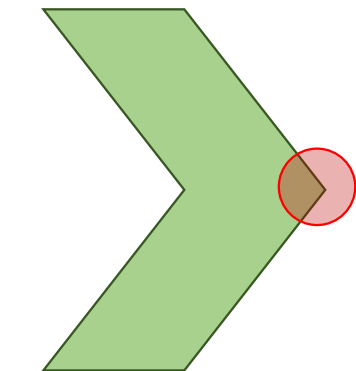


The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.

The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.

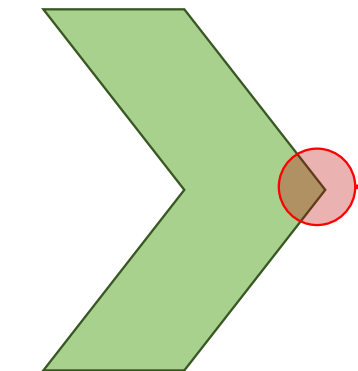


Reconnaissance

This is the **initial phase** of the attack, which is used to select the target and search for vulnerabilities or possible entry points. Here, the attacker tries to prepare an effective **offensive plan**. The reconnaissance stage relies upon a composite set of techniques and processes and is **not limited to technical information**, but also includes details on the physical location of the victim, phone numbers, names of colleagues, etc. It may also heavily rely upon **social engineering**.

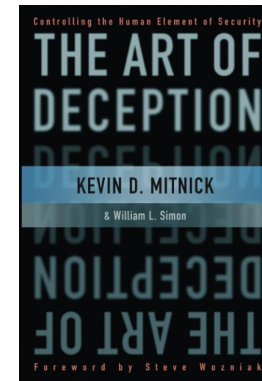
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



Reconnaissance

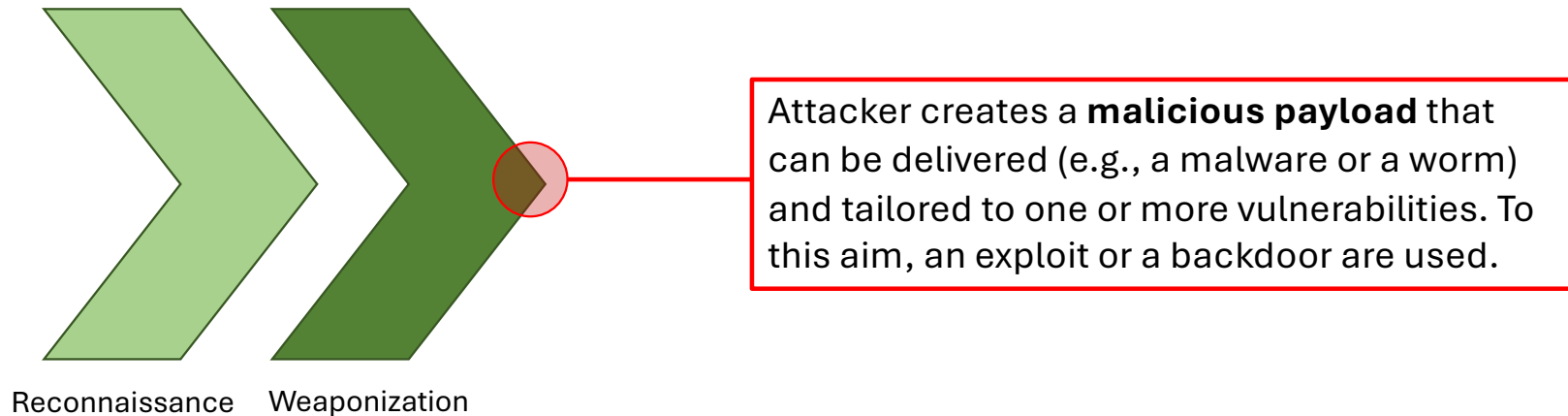
This is the **initial phase** of the attack, which is used to select the target and search for vulnerabilities or possible entry points. Here, the attacker tries to prepare an effective **offensive plan**. The reconnaissance stage relies upon a composite set of techniques and processes and is **not limited to technical information**, but also includes details on the physical location of the victim, phone numbers, names of colleagues, etc. It may also heavily rely upon **social engineering**.



↑ ↑
Suggested book and movie!

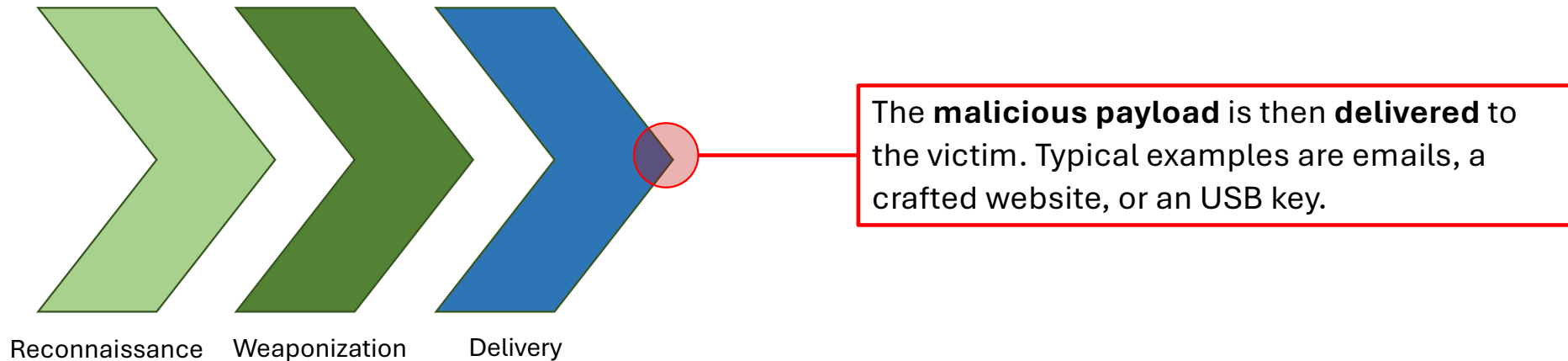
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



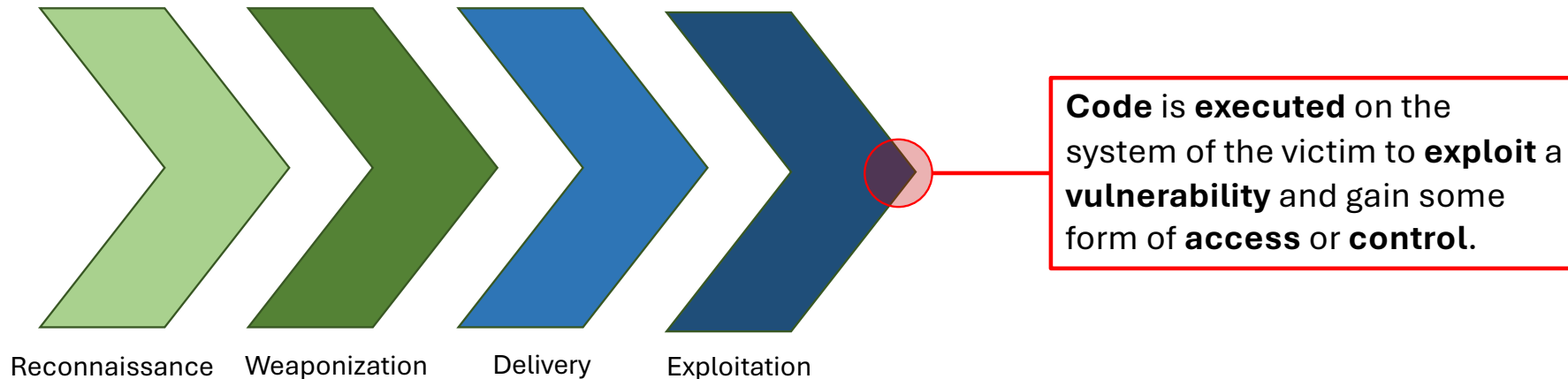
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



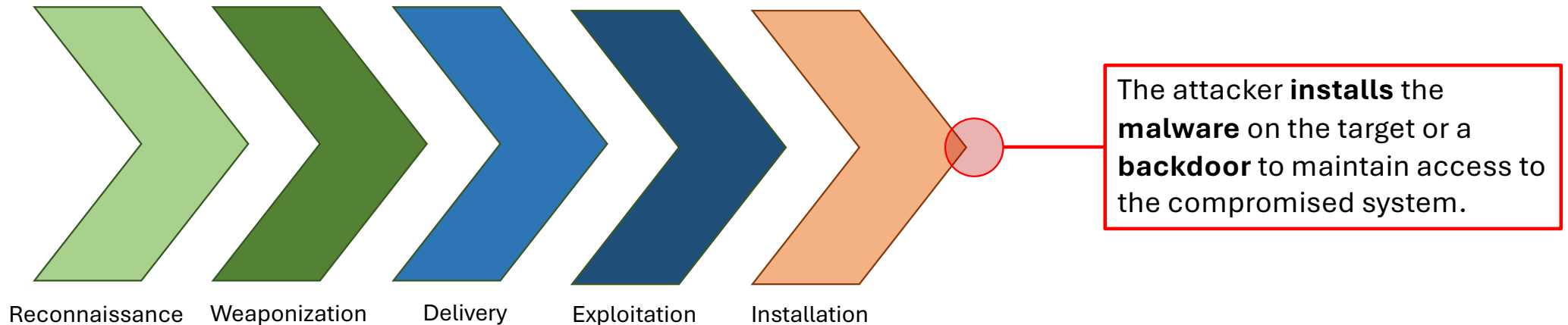
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



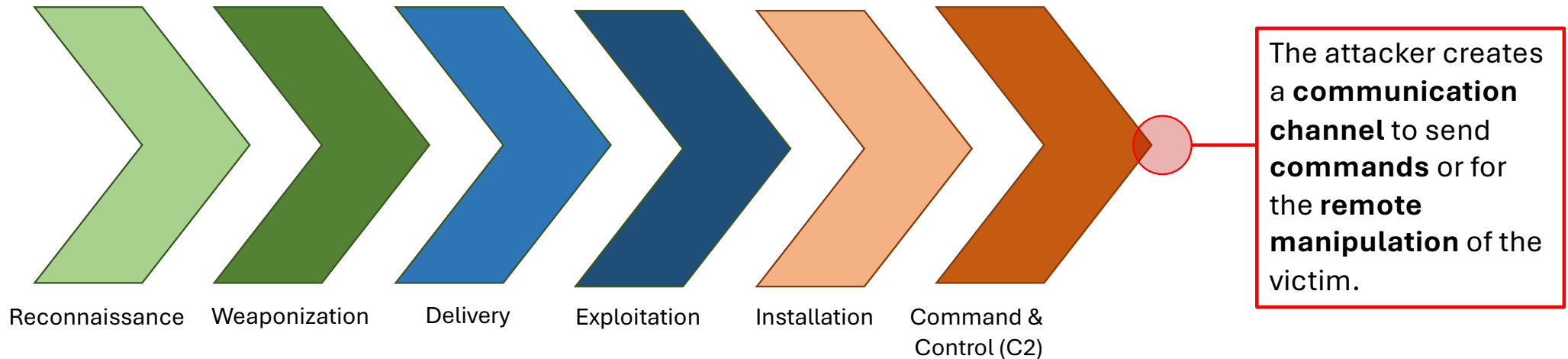
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



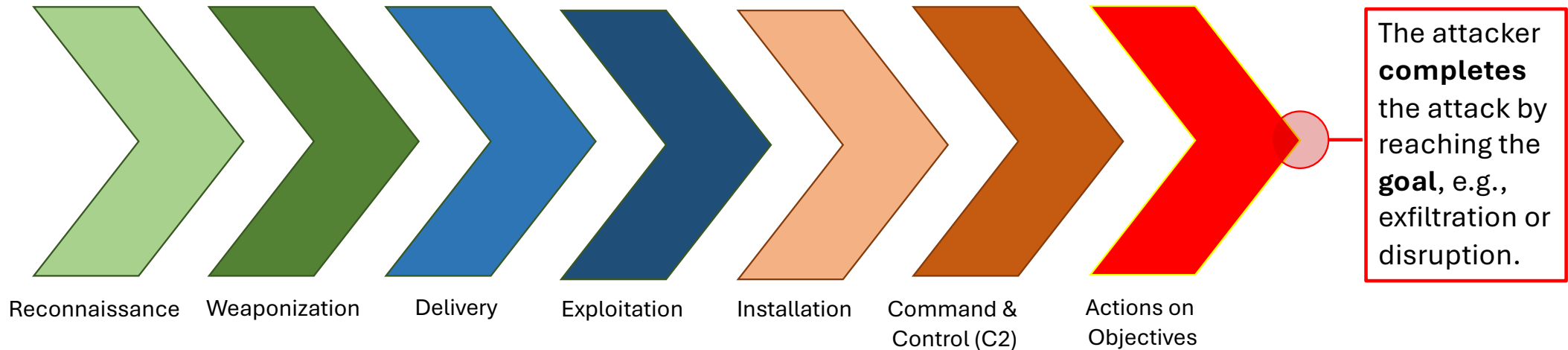
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



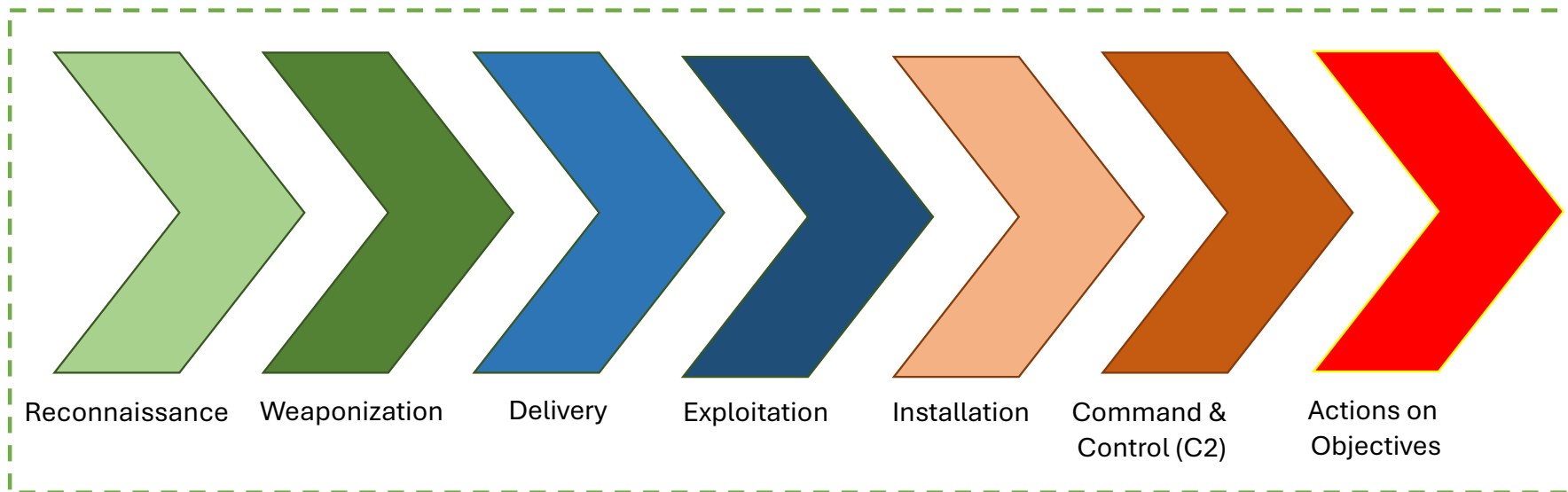
The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



The Cyber Kill Chain®

- Cyber Kill Chain:
 - describes the process used to carry out a cyber attack
 - adaptation of the military kill chain used to outline the structure of an attack
 - proposed by Lockheed-Martin.



The Cyber Kill Chain is especially suited for describing sophisticated attacks, such as **Advanced Persistent Threats (APTs)**

MITRE ATT&CK®

- How adversaries compromise a computing infrastructure can be decomposed into well-defined “actions”.
- MITRE ATT&CK:
 - is a **knowledge base** of adversary behaviors based on real-world observations
 - provides a foundation for the development of **threat models** and countermeasures
 - maintained by MITRE and free.
- The idea is to:
 - describe **what** adversaries try to achieve
 - **how** they operate across an intrusion
 - focus on **observable** behaviors.

MITRE | ATT&CK®

Matrices • Tactics • Techniques • Defenses • CTI • Resources • Benefactors • Contribute • Blog • Search

ATT&CK Matrix for Enterprise

layout: flat • show sub-techniques • hide sub-techniques

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
12 techniques	9 techniques	11 techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Active Scanning (1)	Acquire Access (1)	Content Injection (1)	BITS Jobs (1)	Account Manipulation (1)	Abuse Elevation Control Mechanism (1)	Access Token Manipulation (1)	Disable or Modify System Firewall (1)	Adversary-in-the-Middle (1)	Account Discovery (1)	Exploitation of Remote Services (1)	Adversary-in-the-Middle (1)	Application Layer Protocol (1)	Automated Exfiltration (1)	Account Access Removal (1)
Gather Victim Host Information (1)	Acquire Infrastructure (1)	Drive-by Compromise (1)	Cloud Administration Command (1)	BITS Jobs (1)	Access Token Manipulation (1)	BITS Jobs (1)	Disable or Modify Tools (1)	Brute Force (1)	Application Window Discovery (1)	Internal Spearphishing (1)	Archive Collected Data (1)	Communication Through Removable Media (1)	Data Transfer (1)	Data Destruction (1)
Gather Victim Identity Information (1)	Compromise Accounts (1)	Exploit Public-Facing Application (1)	Command and Scripting Interpreter (1)	Root or Logon Autostart Execution (1)	Account Manipulation (1)	Build Image on Host (1)	Domain or Tenant Policy Modification (1)	Credentials from Password Store (1)	Browser Information Discovery (1)	Remote Session Hijacking (1)	Audio Capture (1)	Content Injection (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Gather Victim Network Information (1)	Compromise Infrastructure (1)	External Remote Services (1)	Container Administration Command (1)	Root or Logon Autostart Execution (1)	Root or Logon Autostart Execution (1)	Debugger Evasion (1)	Downgrade Authentication (1)	Exploitation for Credential Access (1)	Cloud Infrastructure Discovery (1)	Automated Collection (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Gather Victim Org Information (1)	Develop Capabilities (1)	Hardware Additions (1)	Deploy Container (1)	Root or Logon Autostart Execution (1)	Root or Logon Autostart Execution (1)	Declassify/Decode File or Information (1)	Exploitation for Defense Impairment (1)	Exploitation for Credential Access (1)	Cloud Service Dashboard (1)	Remote Session Hijacking (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Phishing for Information (1)	Establish Accounts (1)	Phishing (1)	EDX Administration Command (1)	Cloud Application Integration (1)	Root or Logon Autostart Execution (1)	Direct Volume Access (1)	Exploitation for Defense Impairment (1)	Exploitation for Credential Access (1)	Cloud Storage Object Discovery (1)	Replication Through Removable Media (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Query Public AI Services (1)	Generate Content (1)	Replication Through Removable Media (1)	Exploitation for Client Execution (1)	Cloud Application Integration (1)	Root or Logon Autostart Execution (1)	Execution Guardrails (1)	Exploitation for Defense Impairment (1)	Exploitation for Credential Access (1)	Cloud Storage Object Discovery (1)	Replication Through Removable Media (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Search Closed Sources (1)	Obtain Capabilities (1)	Supply Chain Compromise (1)	Hijack Execution Flow (1)	Create Account (1)	Create or Modify System Process (1)	Exploitation for Stealth (1)	File and Directory Permissions Modification (1)	Forge Web Credentials (1)	Container and Resource Discovery (1)	Replication Through Removable Media (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Search Open Technical Databases (1)	Stage Capabilities (1)	Trusted Relationship (1)	Input Injection (1)	Create or Modify System Process (1)	Domain or Tenant Policy Modification (1)	Hide Artifacts (1)	Input Capture (1)	Input Capture (1)	Debugger Evasion (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Search Open Websites/Domain (1)	Valid Accounts (1)	Valid Accounts (1)	Inter-Process Communication (1)	Event Triggered Execution (1)	Domain or Tenant Policy Modification (1)	Indicator Removal (1)	Modify Authentication Process (1)	Modify Authentication Process (1)	Device Driver Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Search Threat Vendor Data (1)	Wi-Fi Networks (1)	Wi-Fi Networks (1)	Native API (1)	Event Triggered Execution (1)	Domain or Tenant Policy Modification (1)	Indirect Command Execution (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
Search Victim-Owned Websites (1)			Poisoned Pipeline Execution (1)	Exclusive Control (1)	Domain or Tenant Policy Modification (1)	Masquerading (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			Scheduled Task/Job (1)	External Remote Services (1)	Domain or Tenant Policy Modification (1)	Obfuscated Files or Information (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			Serverless Execution (1)	Implant Internal Image (1)	Domain or Tenant Policy Modification (1)	Pre-OS Boot (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			Shared Modules (1)	Modify Registry (1)	Domain or Tenant Policy Modification (1)	Process Injection (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			Software Deployment Tools (1)	Office Application Startup (1)	Domain or Tenant Policy Modification (1)	Reflective Code Loading (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			System Services (1)	Power Settings (1)	Domain or Tenant Policy Modification (1)	Rootkit (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			Trusted Developer Utilities Proxy Execution (1)	Scheduled Task/Job (1)	Domain or Tenant Policy Modification (1)	Selective Exclusion (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			User Execution (1)	Scheduled Task/Job (1)	Domain or Tenant Policy Modification (1)	Social Engineering (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
			Windows Management Instrumentation (1)	Server Software Component (1)	Domain or Tenant Policy Modification (1)	System Binary Proxy Execution (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
				Software Extensions (1)	Domain or Tenant Policy Modification (1)	System Script Proxy Execution (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
					Domain or Tenant Policy Modification (1)	Template Injection (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
					Domain or Tenant Policy Modification (1)	Traffic Signaling (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)
					Domain or Tenant Policy Modification (1)	Weaknesses in Cryptographic Algorithms (1)	Multi-Factor Authentication Interception (1)	Multi-Factor Authentication Interception (1)	Domain Trust Discovery (1)	Software Deployment Tools (1)	Clipboard Data (1)	Exfiltration Over Alternative Protocol (1)	Data Manipulation (1)	Data Encrypted for Impact (1)

MITRE | ATT&CK: <https://attack.mitre.org>

Try it!

MITRE ATT&CK®

- MITRE ATT&CK:
 - stands for Adversarial Tactics, Techniques, and Common Knowledge
 - is pronounced like the word “attack.”
- The name ATT&CK has been chosen to reflect:
 - **adversarial**: the behavior of cyber adversaries
 - **tactics**: objectives of adversary, i.e., **why** an action is performed
 - **techniques**: methods to achieve objectives, i.e., **how** an action is performed
 - **common knowledge**: the shared knowledge base built from adversary behaviors observed in real-world operations.

MITRE ATT&CK®

- The ATT&CK framework can be used for:
 - **Adversary Emulation:** known behaviors can be reproduced to test detection and mitigation capabilities
 - **Red Teaming:** realistic offensive operations can be planned to identify weaknesses of existing defensive mechanisms
 - **Behavioral Analytics:** a suspicious behavior can be modeled independently of malware, tools, or Indicator of Compromise (IoC)
 - **Defensive Gap Assessment:** missing visibility, controls, and mitigations techniques can be identified for a given environment
 - **SOC Maturity Assessment:** the ability of detecting/analyzing and responding to intrusions of a SOC can be thoroughly evaluated.
 - **Cyber Threat Intelligence Enrichment:** observed behaviors of threat actors can be described in a tool-/malware-agnostic manner.

MITRE ATT&CK®

- ATT&CK describes adversary behavior at four levels:
 - **tactic**: the objective that motivates an action
 - **technique**: a method used to achieve a tactic
 - **sub-technique**: a more specific implementation of a technique
 - **procedure**: how a particular adversary implemented a technique in an observed operation, i.e., a concrete example observed in the wild.
- The **same technique** may support **more** than one **tactic**.
- ATT&CK also tries to link techniques to:
 - threat groups
 - software
 - mitigations
 - data sources.

MITRE ATT&CK®

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
12 techniques	9 techniques	11 techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Active Scanning (3)	Acquire Access	Content Injection	BITS Jobs	Account Manipulation (7)	Abuse Elevation Control Mechanism (6)	Access Token Manipulation (5)	Disable or Modify System Firewall (3)	Adversary-in-the-Middle (4)	Account Discovery (4)	Exploitation of Remote Services	Adversary-in-the-Middle (4)	Application Layer Protocol (5)	Automated Exfiltration (1)	Account Access Removal
Gather Victim Host Information (4)	Acquire Infrastructure (8)	Drive-by Compromise	Cloud Administration Command	BITS Jobs	Access Token Manipulation (5)	BITS Jobs	Disable or Modify Tools (6)	Brute Force (4)	Application Window Discovery	Internal Spearphishing	Archive Collected Data (3)	Communication Through Removable Media	Data Transfer Size Limits	Data Destruction (1)
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Command and Scripting Interpreter (13)	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Build Image on Host	Debugger Evasion	Credentials from Password Stores (6)	Browser Information Discovery	Lateral Tool Transfer	Audio Capture	Content Injection	Exfiltration Over Alternative Protocol (3)	Data Encrypted for Impact
Gather Victim Network Information (6)	Compromise Infrastructure (8)	External Remote Services	Container Administration Command	Boot or Logon Initialization Scripts (5)	Boot or Logon Autostart Execution (14)	Delay Execution	Downgrade Attack	Exploitation for Credential Access	Cloud Service Dashboard	Remote Service Session Hijacking (2)	Automated Collection	Data Encoding (2)	Defacement (2)	Data Manipulation (3)
Gather Victim Org Information (4)	Develop Capabilities (4)	Phishing (4)	Deploy Container	Cloud Application Integration	Boot or Logon Initialization Scripts (5)	Decobfuscate/Decode Files or Information	Exploitation for Defense Impairment	Forced Authentication	Cloud Service Discovery	Remote Services (8)	Browser Session Hijacking	Data Obfuscation (3)	Exfiltration Over C2 Channel	Disk Wipe (2)
Phishing for Information (4)	Establish Accounts (3)	Replication Through Removable Media	ESXi Administration Command	Compromise Host Software Binary	Boot or Logon Initialization Scripts (5)	Direct Volume Access	File and Directory Permissions Modification (2)	Forge Web Credentials (2)	Cloud Storage Object Discovery	Replication Through Removable Media	Clipboard Data	Dynamic Resolution (3)	Exfiltration Over Other Network Medium (1)	Email Bombing
Query Public AI Services	Generate Content (2)	Supply Chain Compromise (3)	Exploitation for Client Execution	Create Account (3)	Create or Modify System Process (5)	Execution Guardrails (2)	Modify Authentication Process (9)	Input Capture (4)	Container and Resource Discovery	Software Deployment Tools	Data from Cloud Storage	Encrypted Channel (2)	Exfiltration Over Physical Medium (1)	Endpoint Denial of Service (4)
Search Closed Sources (2)	Obtain Capabilities (7)	Trusted Relationship	Hijack Execution Flow (12)	Create or Modify System Process (5)	Domain or Tenant Policy Modification (2)	Exploitation for Stealth	Modify Cloud Compute Infrastructure (5)	Modify Authentication Process (9)	Debugger Evasion	Taint Shared Content	Data from Configuration Repository (2)	Fallback Channels	Exfiltration Over Physical Medium (1)	Financial Theft
Search Open Technical Databases (5)	Stage Capabilities (6)	Valid Accounts (4)	Input Injection	Event Triggered Execution (18)	Escape to Host	Hide Artifacts (14)	Modify Cloud Resource Hierarchy	Multi-Factor Authentication Interception	Device Driver Discovery	Use Alternate Authentication Material (4)	Data from Information Repositories (6)	Ingress Tool Transfer	Exfiltration Over Web Service (4)	Firmware Corruption
Search Open Websites/Domains (3)		Wi-Fi Networks	Inter-Process Communication (3)	Event Triggered Execution (18)		Hijack Execution Flow (12)	Modify Cloud Resource Hierarchy	Multi-Factor Authentication Interception	Domain Trust Discovery		Data from Local System	Multi-Stage Channels	Scheduled Transfer	Inhibit System Recovery
Search Threat Vendor Data			Native API	Exclusive Control	Exploitation for Privilege Escalation	Indicator Removal (8)	Modify Registry	Multi-Factor Authentication Request Generation	File and Directory Discovery		Data from Network Shared Drive	Non-Application Layer Protocol	Transfer Data to Cloud Account	Resource Hijacking (4)
Search Victim-Owned Websites			Poisoned Pipeline Execution	External Remote Services		Indirect Command Execution	Masquerading (12)	Network Sniffing	Group Policy Discovery		Data from Removable Media	Non-Standard Port		Service Stop
			Scheduled Task/Job (5)	Implant Internal Image	Process Injection (12)		Modify System Image (2)	Log Enumeration	Local Storage Discovery			Protocol Tunneling		System Shutdown/Reboot
			Serverless Execution	Modify Authentication Process (9)	Scheduled Task/Job (5)		Network Boundary Dumping (1)	Network Service Discovery	Network Share Discovery		Data Staged (2)	Proxy (4)		
			Shared Modules	Modify Registry	Valid Accounts (4)		Process Injection (12)	Network Sniffing	Network Service Discovery		Email Collection (3)	Remote Access Tools (3)		
			Software Deployment Tools				Pre-OS Boot (5)	Pre-OS Boot (5)	Network Share Discovery		Input Capture (4)	Traffic Signaling (2)		
			System Services (3)	Office Application Startup (6)		Reflective Code Loading	Pre-OS Boot (5)	Pre-OS Boot (5)	Pre-OS Boot (5)		Screen Capture	Web Service (3)		
			Trusted Developer Utilities Proxy Execution (3)	Power Settings		Rootkit	Scheduled Task/Job (5)	Scheduled Task/Job (5)	Pre-OS Boot (5)		Video Capture			
			User Execution (5)	Pre-OS Boot (5)		Selective Exclusion	Server Software Component (6)	Server Software Component (6)	Pre-OS Boot (5)					
			Windows Management Instrumentation	Scheduled Task/Job (5)		Safe Mode Boot	Software Extensions (2)	Software Extensions (2)	Pre-OS Boot (5)					
				Traffic Signaling (2)		Subvert Trust Controls (6)	Traffic Signaling (2)	Traffic Signaling (2)	Pre-OS Boot (5)					
				Valid Accounts (4)		Weaken Encryption (2)	Trusted Developer Utilities Proxy Execution (3)	Trusted Developer Utilities Proxy Execution (3)	Pre-OS Boot (5)					
							Unused/Unsupported Cloud Regions	Unused/Unsupported Cloud Regions	Pre-OS Boot (5)					
							Valid Accounts (4)	Valid Accounts (4)	Pre-OS Boot (5)					
							Virtualization/Sandbox Evasion (3)	Virtualization/Sandbox Evasion (3)	Pre-OS Boot (5)					
							XSL Script Processing	XSL Script Processing	Pre-OS Boot (5)					

ATT&CK Matrix for Enterprise

MITRE ATT&CK®

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Credential Access	Discovery	Lateral Movement	Collection	Command and Control	Exfiltration	Impact
12 techniques	9 techniques	11 techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques	34 techniques	9 techniques	17 techniques	18 techniques	9 techniques	15 techniques
Active Scanning (3) Gather Victim Host Information (4) Gather Victim Identity Information (3) Gather Victim Network Information (6) Gather Victim Org Information (4) Phishing for Information (4) Query Public AI Services Search Closed Sources (2) Search Open Technical Databases (5) Search Open Websites/Domains (3) Search Threat Vendor Data Search Victim-Owned Websites	Acquire Access Acquire Infrastructure (8) Compromise Accounts (3) Compromise Infrastructure (8) Develop Capabilities (4) Establish Accounts (3) Generate Content (2) Obtain Capabilities (7) Stage Capabilities (6)	Content Injection Drive-by Compromise Exploit Public-Facing Application External Remote Services Hardware Additions Phishing (4) Replication Through Removable Media Supply Chain Compromise (3) Trusted Relationship Valid Accounts (4) Wi-Fi Networks	BITS Jobs Cloud Administration Command Command and Scripting Interpreter (13) Container Administration Command Deploy Container ESXi Administration Command Exploitation for Client Execution Hijack Execution Flow (2) Input Injection Inter-Process Communication (3) Native API Poisoned Pipeline Execution Scheduled Task/Job (5) Serverless Execution Shared Modules Software Deployment Tools System Services (3) Trusted Developer Utilities Proxy Execution (3) User Execution (5) Windows Management Instrumentation	Account Manipulation (7) BITS Jobs Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Cloud Application Integration Compromise Host Software Binary Create Account (3) Create or Modify System Process (5) Event Triggered Execution (18) Exclusive Control External Remote Services Implant Internal Image Modify Authentication Process (9) Modify Registry Office Application Startup (6) Power Settings Pre-OS Boot (8) Scheduled Task/Job (5) Server Software Component (6) Software Extensions (2) Traffic Signaling (2) Valid Accounts (4)	Abuse of Elevation Control Mechanism (6) Access Token Manipulation (5) Account Manipulation (7) Account Manipulation (7) Boot or Logon Autostart Execution (14) Boot or Logon Initialization Scripts (5) Create or Modify System Process (5) Domain or Tenant Policy Modification (2) Escape to Host Event Triggered Execution (18) Exploitation for Privilege Escalation Process Injection (12) Scheduled Task/Job (5) Valid Accounts (4)	Access Token Manipulation (5) BITS Jobs Build Image on Host Debugger Evasion Delay Execution Deobfuscate/Decode Files or Information Direct Volume Access Execution Guardrails (2) Exploitation for Stealth Hide Artifacts (14) Indicator Removal (8) Indirect Command Execution Masquerading (12) Obfuscated Files or Information (18) Pre-OS Boot (5) Process Injection (12) Reflective Code Loading Rootkit Selective Exclusion Social Engineering (2) System Binary Proxy Execution (14) System Script Proxy Execution (2) Template Injection Traffic Signaling (2) Trusted Developer Utilities Proxy Execution (3) Unused/Unsupported Cloud Regions Valid Accounts (4) Virtualization/Sandbox Evasion (3) XSL Script Processing	Disable or Modify System Firewall (3) Disable or Modify Tools (6) Domain or Tenant Policy Modification (2) Downgrade Attack Exploitation for Defense Impairment File and Directory Permissions Modification (2) Modify Authentication Process (9) Modify Cloud Compute Infrastructure (5) Modify Cloud Resource Hierarchy Modify Registry Modify System Image (2) Network Boundary Bridging (1) Plist File Modification Prevent Command History Logging Rogue Domain Controller Self-Modifying Binary Subvert Trust Controls (6) Weaken Encryption (2)	Adversary-in-the-Middle (4) Brute Force (4) Credentials from Password Stores (6) Exploitation for Credential Access Forced Authentication Forge Web Credentials (2) Input Capture (4) Modify Authentication Process (9) Multi-Factor Authentication Interception Multi-Factor Authentication Request Generation Network Sniffing OS Credential Dumping (8) Steal Application Access Token Steal or Forge Authentication Certificates Steal Web Session Cookie Unsecured Credentials (8)	Account Discovery (4) Application Window Discovery Browser Information Discovery Cloud Infrastructure Discovery Cloud Service Dashboard Cloud Service Discovery Cloud Storage Object Discovery Container and Resource Discovery Debugger Evasion Device Driver Discovery Domain Trust Discovery File and Directory Discovery Local Storage Discovery Log Enumeration Network Service Discovery Network Share Discovery Network Sniffing Password Policy Discovery Peripheral Device Discovery Permission Groups Process Discovery Query Registry Remote System Discovery Software Discovery (2) System Information Discovery System Location Discovery (1) System Network Configuration Discovery (2) System Network Connections Discovery System Owner/User Discovery System Service Discovery System Time Discovery Virtual Machine Discovery Virtualization/Sandbox Evasion (3)	Exploitation of Remote Services Internal Spearphishing Lateral Tool Transfer Remote Service Session Hijacking (2) Remote Services (8) Replication Through Removable Media Software Deployment Tools Taint Shared Content Use Alternate Authentication Material (4)	Adversary-in-the-Middle (4) Archive Collected Data (3) Audio Capture Automated Collection Browser Session Hijacking Clipboard Data Data from Cloud Storage Data from Configuration Repository (2) Data from Information Repositories (6) Data from Local System Data from Network Shared Drive Data from Removable Media Data Staged (2) Email Collection (3) Input Capture (4) Screen Capture Video Capture	Application Layer Protocol (5) Communication Through Removable Media Content Injection Data Encoding (2) Data Obfuscation (3) Dynamic Resolution (3) Encrypted Channel (2) Fallback Channels Hide Infrastructure Ingress Tool Transfer Multi-Stage Channels Non-Application Layer Protocol Non-Standard Port Protocol Tunneling Proxy (4) Remote Access Tools (3) Traffic Signaling (2) Web Service (3)	Automated Exfiltration (1) Data Transfer Size Limits Exfiltration Over Alternative Protocol (3) Exfiltration Over C2 Channel Exfiltration Over Other Network Medium (1) Exfiltration Over Physical Medium (1) Exfiltration Over Web Service (4) Scheduled Transfer Transfer Data to Cloud Account	Account Access Removal Data Destruction (1) Data Encrypted for Impact Data Manipulation (3) Defacement (2) Disk Wipe (2) Email Bombing Endpoint Denial of Service (4) Financial Theft Firmware Corruption Inhibit System Recovery Network Denial of Service (2) Resource Hijacking (4) Service Stop System Shutdown/Reboot

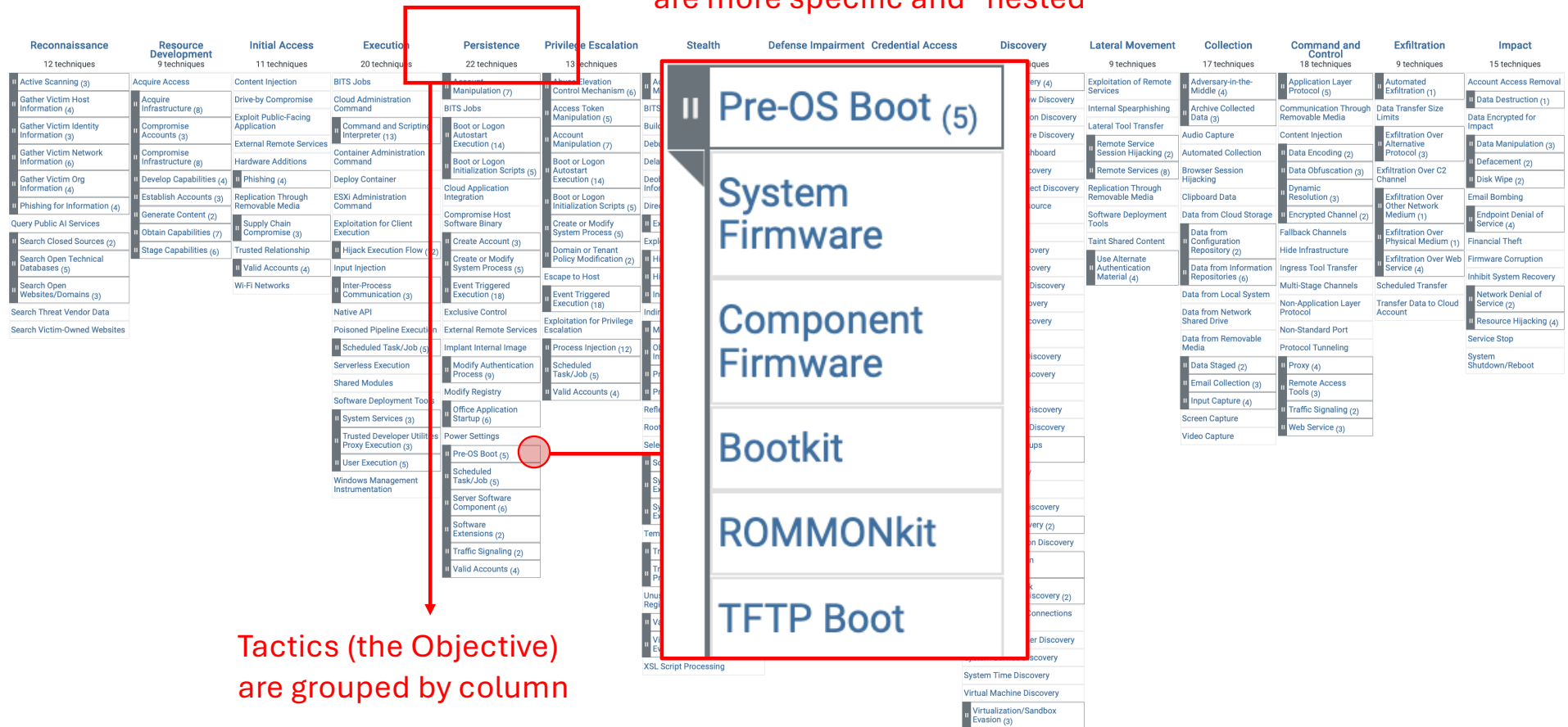
Tactics (the Objective) are grouped by column

Techniques (the how) are items in the column

ATT&CK Matrix for Enterprise

MITRE ATT&CK®

Sub-techniques (the how)
are more specific and “nested”



MITRE ATT&CK®

Reconnaissance12 techniques

Active Scanning (3)

Gather Victim Host Information (4)

Gather Victim Identity Information (3)

Gather Victim Network

Resource Development9 techniques

Acquire Access

Acquire Infrastructure (8)

Compromise Accounts (3)

Compromise

Initial Access11 techniques

Content Injection

Drive-by Compromise

Exploit Public-Facing Application

External Remote Services

Execution20 techniques

BITS Jobs

Cloud Administration Command

Command and Scripting Interpreter (13)

Container Administration

Persistence22 techniques

Account Manipulation (7)

BITS Jobs

Boot or Logon Autostart Execution (14)

Privilege Escalation13 techniques

Abuse Elevation Control Mechanism (6)

Access Token Manipulation (5)

Account Manipulation (7)

Stealth

Defense Impairment

Credential Access

Discovery

Lateral Movement9 techniques

Exploitation of Remote Services

Internal Spearphishing

Lateral Tool Transfer

Remote Service Session Hijacking (2)

Remote Services (8)

Replication Through Removable Media

Software Deployment Tools

Taint Shared Content

Use Alternate Authentication Material (4)

Collection17 techniques

Adversary-in-the-Middle (4)

Archive Collected Data (3)

Audio Capture

Automated Collection

Browser Session Hijacking

Clipboard Data

Data from Cloud Storage

Data from Configuration Repository (2)

Data from Information Repositories (6)

Data from Local System

Data from Network Shared Drive

Data from Removable Media

Data Staged (2)

Email Collection (3)

Input Capture (4)

Screen Capture

Video Capture

Command and Control18 techniques

Application Layer Protocol (5)

Communication Through Removable Media

Content Injection

Data Encoding (2)

Data Obfuscation (3)

Dynamic Resolution (3)

Encrypted Channel (2)

Fallback Channels

Hide Infrastructure

Ingress Tool Transfer

Multi-Stage Channels

Non-Application Layer Protocol

Non-Standard Port

Protocol Tunneling

Proxy (4)

Remote Access Tools (3)

Traffic Signaling (2)

Web Service (3)

Exfiltration9 techniques

Automated Exfiltration (1)

Data Transfer Size Limits

Exfiltration Over Alternative Protocol (3)

Exfiltration Over C2 Channel

Exfiltration Over Other Network Medium (1)

Exfiltration Over Physical Medium (1)

Exfiltration Over Web Service (4)

Scheduled Transfer

Transfer Data to Cloud Account

Impact15 techniques

Account Access Removal

Data Destruction (1)

Data Encrypted for Impact

Data Manipulation (3)

Defacement (2)

Disk Wipe (2)

Email Bombing

Endpoint Denial of Service (4)

Financial Theft

Firmware Corruption

Inhibit System Recovery

Network Denial of Service (2)

Resource Hijacking (4)

Service Stop

System Shutdown/Reboot

Pre-OS Boot: System Firmware

Other sub-techniques of Pre-OS Boot (5)

Adversaries may modify system firmware to persist on systems. The BIOS (Basic Input/Output System) and The Unified Extensible Firmware Interface (UEFI) or Extensible Firmware Interface (EFI) are examples of system firmware that operate as the software interface between the operating system and hardware of a computer.^{[1][2][3]}

System firmware like BIOS and (U)EFI underly the functionality of a computer and may be modified by an adversary to perform or assist in malicious activity. Capabilities exist to overwrite the system firmware, which may give sophisticated adversaries a means to install malicious firmware updates as a means of persistence on a system that may be difficult to detect.

Procedure Examples

ID	Name	Description
S0047	Hacking Team UEFI Rootkit	Hacking Team UEFI Rootkit is a UEFI BIOS rootkit developed by the company Hacking Team to persist remote access software on some targeted systems. ^[4]
S0397	LoJax	LoJax is a UEFI BIOS rootkit deployed to persist remote access software on some targeted systems. ^[5]
S0001	Trojan.Mebromi	Trojan.Mebromi performs BIOS modification and can download and execute a file as well as protect itself from removal. ^[6]

ID: T1542.001

Sub-technique of: T1542

Tactics: Stealth, Persistence

Platforms: Network Devices, Windows

Contributors: Jean-Ian Boutin, ESET; McAfee; Ryan Becwar

Version: 2.0

Created: 19 December 2019

Last Modified: 12 May 2026

Version Permalink

Pre-OS Boot (5)

System Firmware

Component Firmware

Bootkit

ROMMONkit

TFTP Boot

XSL Script Processing

System Time Discovery

Virtual Machine Discovery

Virtualization/Sandbox Evasion (3)

Detailed information of a Procedure

ATT&CK Matrix for Enterprise

MITRE ATT&CK®

- ATT&CK offers different separate knowledge bases to:
 - define the ecosystem an adversary operates within
 - provide a set of constraints the adversary must circumvent or exploit.
- MITRE provides **three** technology domains:
 - **Enterprise**: representing traditional enterprise networks and cloud deployments
 - **Mobile**: representing mobile devices
 - **Industrial Control Systems**: representing industrial settings.

MITRE ATT&CK®

- Techniques and sub-Techniques:
 - are organized according to a very precise object structure
 - more details in the “*MITRE ATT&CK®: Design and Philosophy*” document(*).
- Main items of the used data model are:
 - **Name**: official name of the technique or sub-technique
 - **ID**: unique identifier formalized as **T####** or **T####.###**
 - **Sub-techniques**: IDs of the sub-techniques associated with a parent one
 - **Tactic**: objectives that the technique can accomplish
 - **Description**: technical explanation and known adversary uses
 - **Platform**: OS or applications to which the behavior applies
 - **Procedure Examples**: documented uses by specific groups or software
 - **Detection**: vendor-neutral strategies for identifying the behavior
 - **Mitigation**: mechanisms that can prevent or limit the behavior.

(*) https://attack.mitre.org/docs/ATTACK_Design_and_Philosophy_March_2020.pdf

MITRE ATT&CK®

Pre-OS Boot: Component Firmware

Other sub-techniques of Pre-OS Boot (5) ▾

Adversaries may modify component firmware to persist on systems. Some adversaries may employ sophisticated means to compromise computer components and install malicious firmware that will execute adversary code outside of the operating system and main system firmware or BIOS. This technique may be similar to [System Firmware](#) but conducted upon other system components/devices that may not have the same capability or level of integrity checking.

Malicious component firmware could provide both a persistent level of access to systems despite potential typical failures to maintain access and hard disk re-images, as well as a way to evade host software-based defenses and integrity checks.

ID: T1542.002

Sub-technique of: [T1542](#)

🕒 Tactics: [Stealth](#), [Persistence](#)

🕒 Platforms: Linux, Windows, macOS

Version: 2.0

Created: 19 December 2019

Last Modified: 12 May 2026

[Version Permalink](#)

Support **more**
than one tactic

Procedure Examples

ID	Name	Description
S0687	Cyclops Blink	Cyclops Blink has maintained persistence by patching legitimate device firmware when it is downloaded, including that of WatchGuard devices. ^[1]
G0020	Equation	Equation is known to have the capability to overwrite the firmware on hard drives from some manufacturers. ^[2]

Mitigations

ID	Mitigation	Description
M1051	Update Software	Perform regular firmware updates to mitigate risks of exploitation and/or abuse.

Detection Strategy

ID	Name	Analytic ID	Analytic Description
DET0323	Detection Strategy for T1542.002 Pre-OS Boot: Component Firmware	AN0916	Detection of anomalous driver and firmware interactions, including unsigned or unexpected firmware updates, driver loads linked to hardware components, and suspicious use of privileged APIs to read/write firmware or controller memory.
		AN0917	Detection of suspicious use of ioctl/sysfs calls to access device firmware, unexpected flashing tools execution, and anomalous firmware checksums logged by SMART or kernel audit mechanisms.
		AN0918	Detection of EFI/firmware manipulation attempts via abnormal driver loads, unsigned kexts, or tampered NVRAM variables associated with component firmware configuration.

Example of Pre-OS Boot: Component Firmware

MITRE ATT&CK®

OS Credential Dumping

Sub-techniques (8)

Adversaries may attempt to dump credentials to obtain account login and credential material, normally in the form of a hash or a clear text password. Credentials can be obtained from OS caches, memory, or structures.^[1] Credentials can then be used to perform Lateral Movement and access restricted information.

Several of the tools mentioned in associated sub-techniques may be used by both adversaries and professional security testers. Additional custom tools likely exist as well.

ID: T1003
Sub-techniques: T1003.001, T1003.002, T1003.003, T1003.004, T1003.005, T1003.006, T1003.007, T1003.008
① Tactic: Credential Access
① Platforms: Linux, Windows, macOS
Contributors: Ed Williams, Trustwave, SpiderLabs, Tim (Wadhwa) Brown, Vincent Le Toux, Yves Yonan
Version: 2.2
Created: 31 May 2017
Last Modified: 24 October 2025

[Version](#) [Permalink](#)

Procedure Examples

ID	Name	Description
G0007	APT28	APT28 regularly deploys both publicly available (ex: Mimikatz) and custom password retrieval tools on victims. ^{[2][3][4]}
G0050	APT32	APT32 used GetPassword_x64 to harvest credentials. ^{[5][6]}
G0087	APT39	APT39 has used different versions of Mimikatz to obtain credentials. ^[7]
G0001	Axiom	Axiom has been known to dump credentials. ^[8]
G1043	BlackByte	BlackByte used tools such as Cobalt Strike and Mimikatz to dump credentials from victim systems. ^{[9][10]}
S0030	Carbanak	Carbanak obtains Windows logon password details. ^[11]
G1003	Ember Bear	Ember Bear gathers credential material from target systems, such as SSH keys, to facilitate access to victim environments. ^[12]
S0232	HOMEFRY	HOMEFRY can perform credential dumping. ^[13]
G0065	Leviathan	Leviathan has used publicly available tools to dump password hashes, including HOMEFRY. ^[14]
S1146	MgBot	MgBot includes modules for dumping and capturing credentials from process memory. ^[15]
G0129	Mustang Panda	Mustang Panda utilized "Hdump" to dump credentials from memory. ^[16]
S0052	OnionDuke	OnionDuke steals credentials from its victims. ^[17]
S0048	PinchDuke	PinchDuke steals credentials from compromised hosts. PinchDuke's credential stealing functionality is believed to be based on the source code of the Pinch credential stealing malware (also known as LdPinch). Credentials targeted by PinchDuke include ones associated many sources such as Wininet Credential Cache, and Lightweight Directory Access Protocol (LDAP). ^[17]
G0033	Poseidon Group	Poseidon Group conducts credential dumping on victims, with a focus on obtaining credentials belonging to domain and database servers. ^[18]
S0379	Revenge RAT	Revenge RAT has a plugin for credential harvesting. ^[19]
G0054	Sowbug	Sowbug has used credential dumping tools. ^[20]
G1053	Storm-0501	Storm-0501 has used the SecretsDump module within Impacket can perform credential dumping to obtain account and password information. ^[21]
G0039	Suckfly	Suckfly used a signed credential-dumping tool to obtain victim account credentials. ^[22]
G0131	Tonto Team	Tonto Team has used a variety of credential dumping tools. ^[23]
S0094	Trojan.Karagany	Trojan.Karagany can dump passwords and save them into %ProgramData%\Mail\%MailAg%\peds.txt. ^[24]

ATT&CK also reports data about **groups**, i.e., known adversaries documented by public and private organizations in threat intelligence reports.

ATT&CK mainly focuses on APTs but may also include other advanced actors, such as financially-motivated groups.

Example of OS Credential Dumping

MITRE ATT&CK®

- Example - WannaCry mapped to MITRE ATT&CK:
 - **Discovery (TA0007)**: identifies other systems on the network (**Remote System Discovery - T1018**)
 - **Lateral Movement (TA0008)**: exploits SMBv1 to spread between systems (**Exploitation of Remote Services - T1210**)
 - **Lateral Movement (TA0008)**: copies itself to compromised computers (**Lateral Tool Transfer - T1570**)
 - **Persistence (TA0003)**: creates a Windows service (**Windows Service - T1543.003**)
 - **Impact (TA0040)**: disables recovery mechanisms (**Inhibit System Recovery - T1490**)
 - **Impact (TA0040)**: encrypts files and demands a ransom (**Data Encrypted for Impact - T1486**).

MITRE ATT&CK®

- Example - SolarWinds Compromise mapped to MITRE ATT&CK:
 - **Actor:** **APT29**
 - **Initial Access (TA0001):** delivers a trojanized Orion software update (**Compromise Software Supply Chain - T1195.002**)
 - **Execution (TA0002):** executes commands and payloads with PowerShell (**PowerShell - T1059.001**)
 - **Persistence (TA0003):** creates or modifies scheduled tasks (**Scheduled Task - T1053.005**)
 - **Credential Access (TA0006):** replicates Active Directory data (**DCSync - T1003.006**)
 - **Lateral Movement (TA0008):** uses RDP to access internal servers (**Remote Desktop Protocol - T1021.001**)
 - **Exfiltration (TA0010):** sends staged data through HTTPS (**Exfiltration Over Asymmetric Encrypted Non-C2 Protocol - T1048.002**).

Source: <https://attack.mitre.org/campaigns/C0024/>

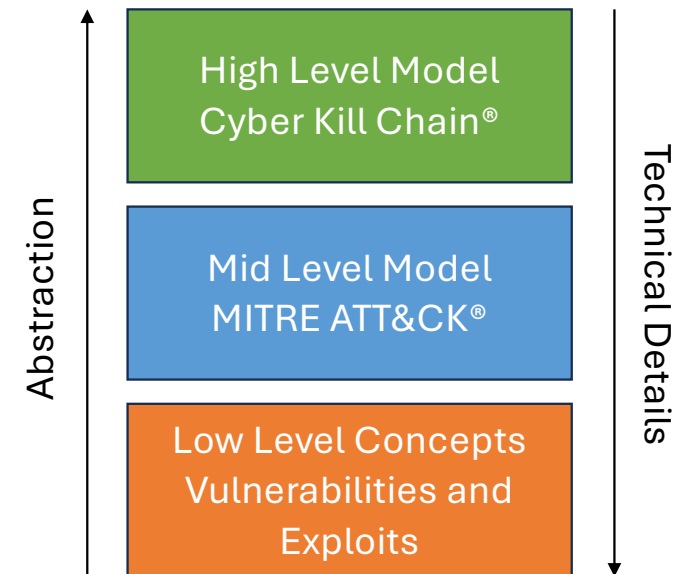
MITRE ATT&CK®

- Example - NotPetya mapped to MITRE ATT&CK:
 - **Actor:** Sandworm Team
 - **Execution (TA0002):** propagates through Windows Management Instrumentation (**Windows Management Instrumentation - T1047**)
 - **Credential Access (TA0006):** extracts credentials from LSASS memory (**OS Credential Dumping: LSASS Memory - T1003.001**)
 - **Discovery (TA0007):** searches for files before encryption (**File and Directory Discovery - T1083**)
 - **Lateral Movement (TA0008):** exploits SMBv1 to spread between systems (**Exploitation of Remote Services - T1210**)
 - **Lateral Movement (TA0008):** executes commands through ADMIN\$ and PsExec (**SMB/Windows Admin Shares - T1021.002**)
 - **Impact (TA0040):** encrypts files and disk structures (**Data Encrypted for Impact - T1486**).

Source: <https://attack.mitre.org/software/S0368/>

Modeling Abstractions

- The Cyber Kill Chain:
 - provides a **high-level** view of the attack lifecycle and adversary goals
 - does not provide details on individual actions or their relationships.
- Exploit and vulnerability databases:
 - operate at a low level
 - describe specific vulnerable software
 - provide a **limited context** on when and why exploits are used.
- MITRE ATT&CK:
 - is a sort of “glue”
 - breaks goals into tactics
 - place exploits and malware in **operational contexts**.



Attack Surface

- An **attack surface** is:
 - the **sum** of all **entry points** and **vulnerabilities** that an **adversary** can **exploit** to attack a system.
- There are different attack surfaces that may coexist:
 - **hardware**: devices and USB ports or drives
 - **cloud**: resource-as-commodity infrastructures used by an organization
 - **physical**: physical access points that can be exploited.

Attack Surface

- An **attack surface** is:
 - the **sum** of all **entry points** and **vulnerabilities** that an **adversary** can **exploit** to attack a system.
- There are different attack surfaces that may coexist:
 - **hardware**: devices and USB ports or drives
 - **cloud**: resource-as-commodity infrastructures used by an organization
 - **physical**: physical access points that can be exploited.



myself walking near Torriglia (GE)

Attack Surface



Attacker

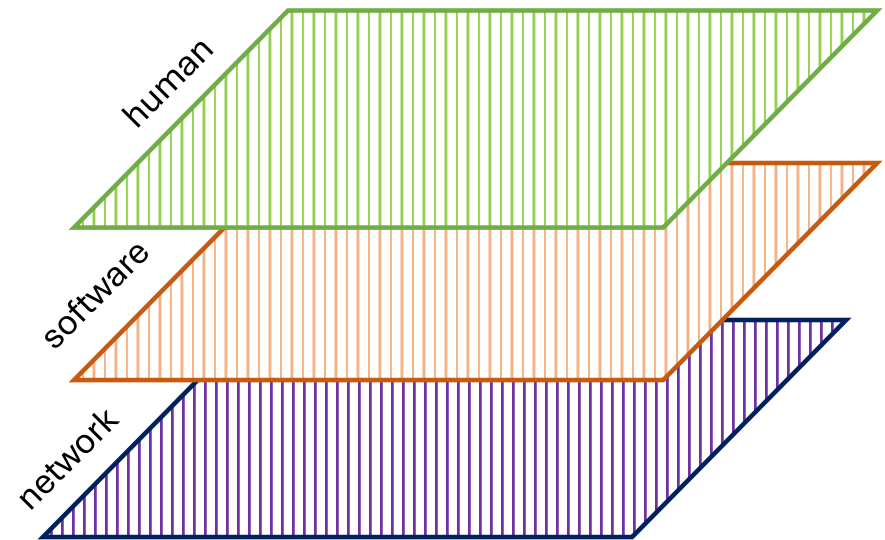
- In this course we are **interested** in:

By Product

- **human attack surface:** outlined by vulnerabilities caused by people, e.g., via social engineering, human errors, and insiders

Main Focus

- **software attack surface:** outlined by vulnerabilities plaguing applications, operating systems, firmware, and software ecosystems
- **network attack surface:** outlined by vulnerabilities of wide-area networks or the Internet, e.g., firewall configurations.



VICTIM

Victim

Attack Surface

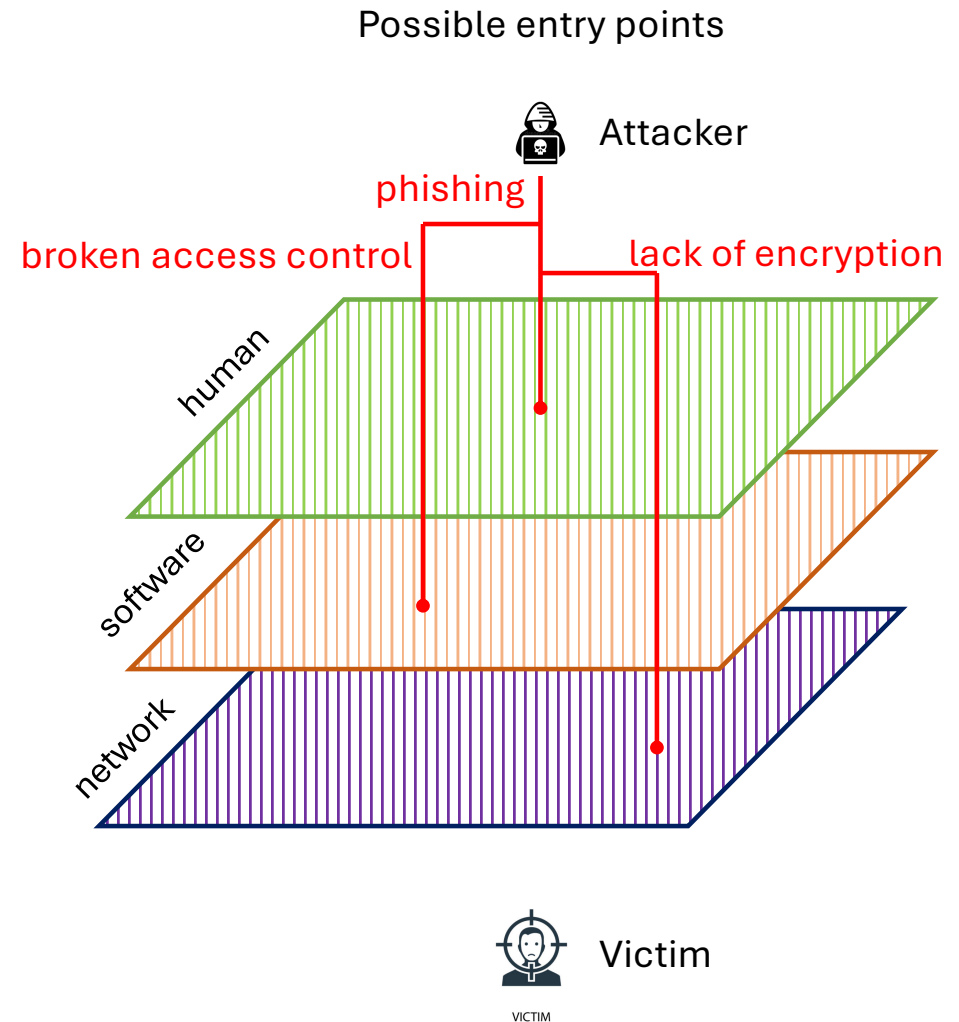
- In this course we are **interested** in:

By Product

- **human attack surface:** outlined by vulnerabilities caused by people, e.g., via social engineering, human errors, and insiders

Main Focus

- **software attack surface:** outlined by vulnerabilities plaguing applications, operating systems, firmware, and software ecosystems
- **network attack surface:** outlined by vulnerabilities of wide-area networks or the Internet, e.g., firewall configurations.

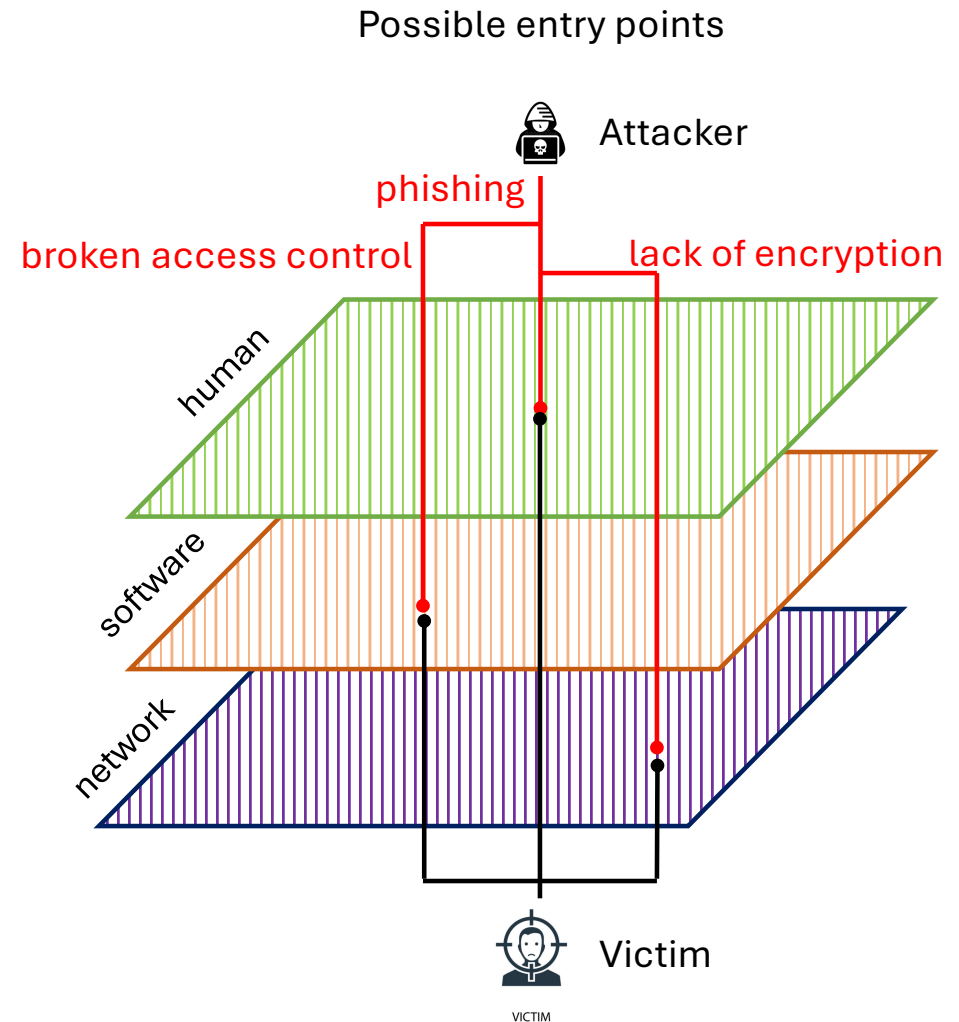


Attack Surface

- In this course we are **interested** in:
 - **human attack surface**: outlined by vulnerabilities caused by people, e.g., via social engineering, human errors, and insiders
 - **software attack surface**: outlined by vulnerabilities plaguing applications, operating systems, firmware, and software ecosystems
 - **network attack surface**: outlined by vulnerabilities of wide-area networks or the Internet, e.g., firewall configurations.

By Product

Main Focus

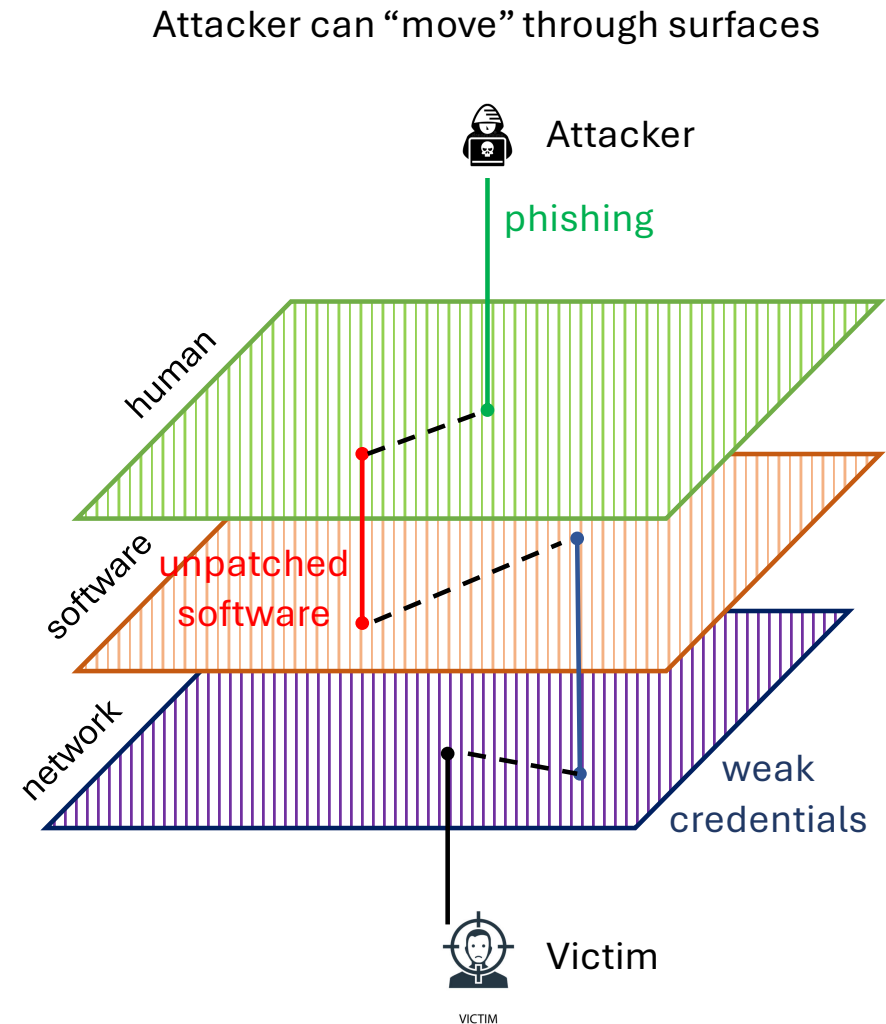


Attack Surface

- In this course we are **interested** in:
 - **human attack surface**: outlined by vulnerabilities caused by people, e.g., via social engineering, human errors, and insiders
 - **software attack surface**: outlined by vulnerabilities plaguing applications, operating systems, firmware, and software ecosystems
 - **network attack surface**: outlined by vulnerabilities of wide-area networks or the Internet, e.g., firewall configurations.

By Product

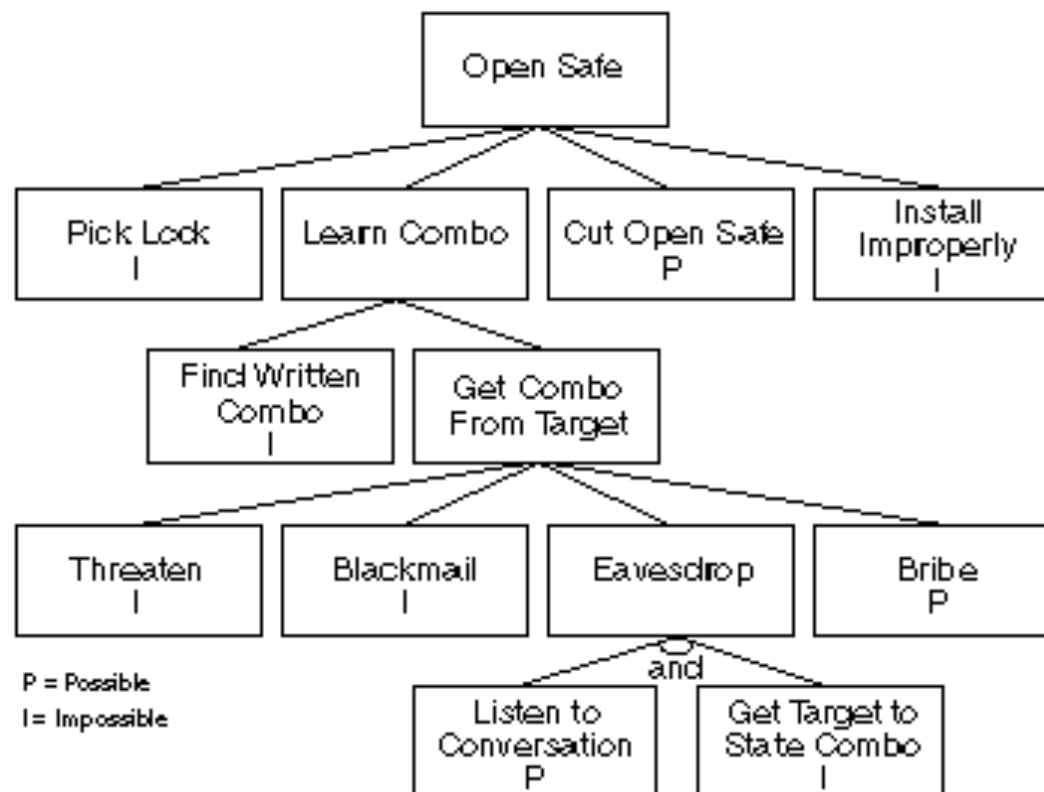
Main Focus



Attack Tree

- An **attack tree** is a conceptual diagram that shows how a target can be attacked.
- Basic concepts:
 - the **goal** of the attack is **the root node** of the tree
 - the **ways** that an attacker could reach that goal are **branches** and **subnodes**
 - each **subnode** defines a **subgoal** (each **subgoal** may have its own set of further **subgoals**)
 - the **leaves** of the tree are the **different ways** for **initiating** an attack.
- Other concepts:
 - **nodes** other than a leaf is either an **AND-node** or an **OR-node**
 - **branches** can be **labeled** with values representing difficulty, cost, or other attack attributes (attacks can be then compared).

Attack Tree: A “Classic” Example

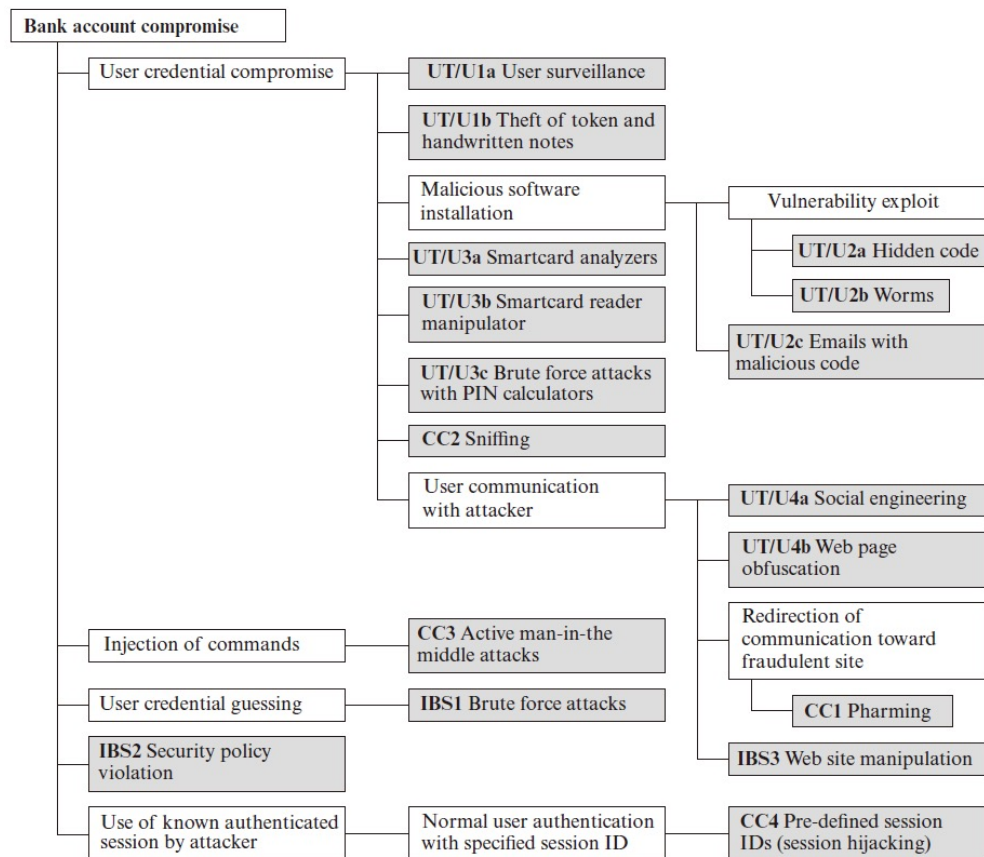


Bruce Schneier



Source: https://www.schneier.com/academic/archives/1999/12/attack_trees.html

Attack Tree: Internet Banking Authentication



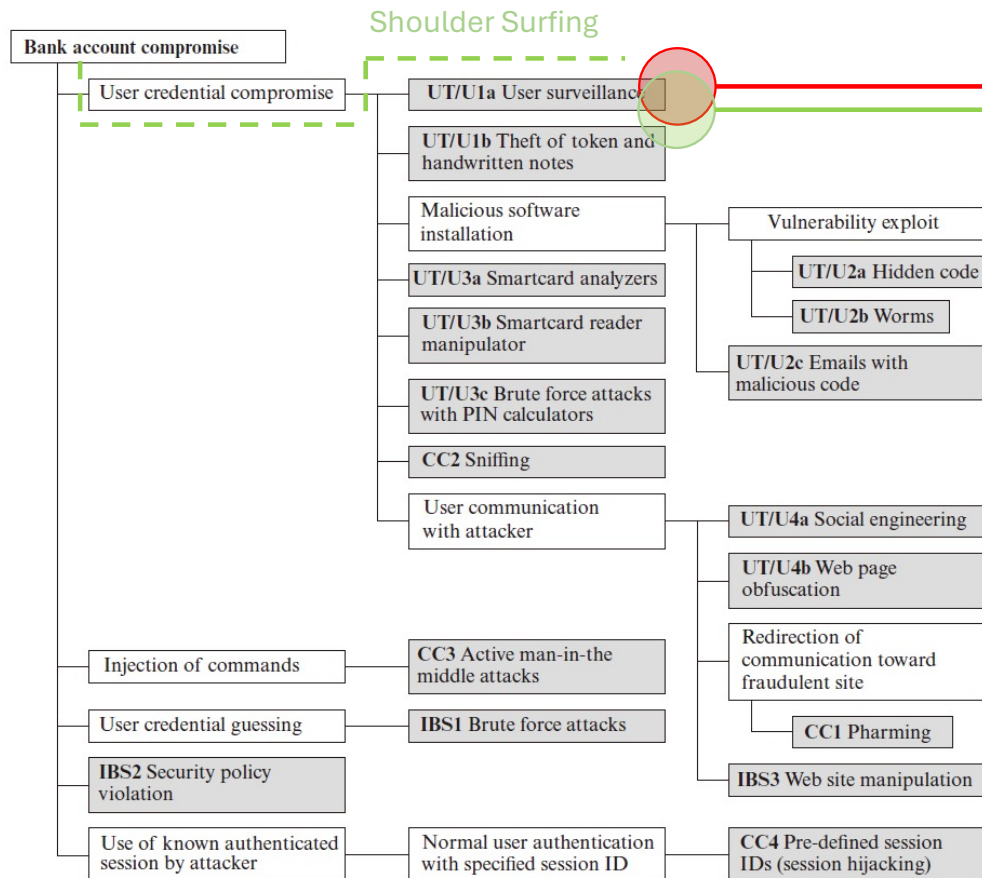
Legend:

User Terminal and User (UT/U): attacks targeting the user equipment, including smartcards and password/token generators; they also include actions of the user.

Communications Channel (CC): attacks focusing on communication links.

Internet Banking Server (IBS): attacks targeting hosts/nodes running the banking application.

Attack Tree: Internet Banking Authentication



The **attacker simplest path** principle: an attacker usually exploits the path of least resistance, which is the most straightforward, low-effort route for exploiting vulnerabilities and achieve his/her/their goal.

The “**simplest path**” is often found in overlooked, externally-exposed, or misconfigured systems and resources.

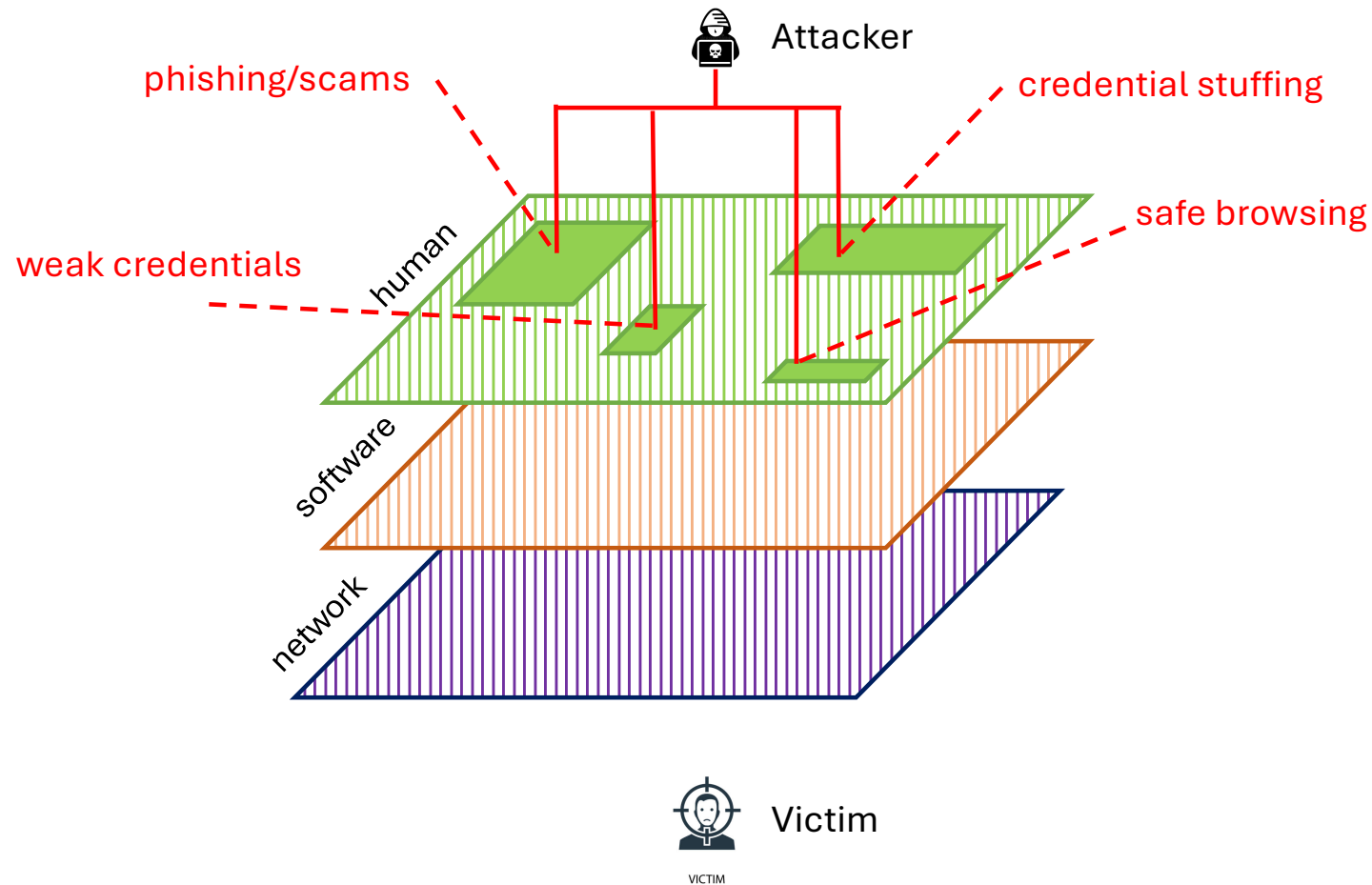


Attack Surface Reduction

- The **attack surface reduction** is the process of minimizing:
 - potential entry points
 - vulnerabilities
 - chances of attacking a system/network.
- Possible strategies:
 - **Zero-trust policies**: enforce that only the **right people** have the **right level** of access
 - **Access control**: give to users and applications only the permissions they need to perform their tasks, i.e., **least privilege principle**
 - **Training/Education**: train users on cybersecurity best practices, e.g., recognize phishing and scams.



Attack Surface Reduction

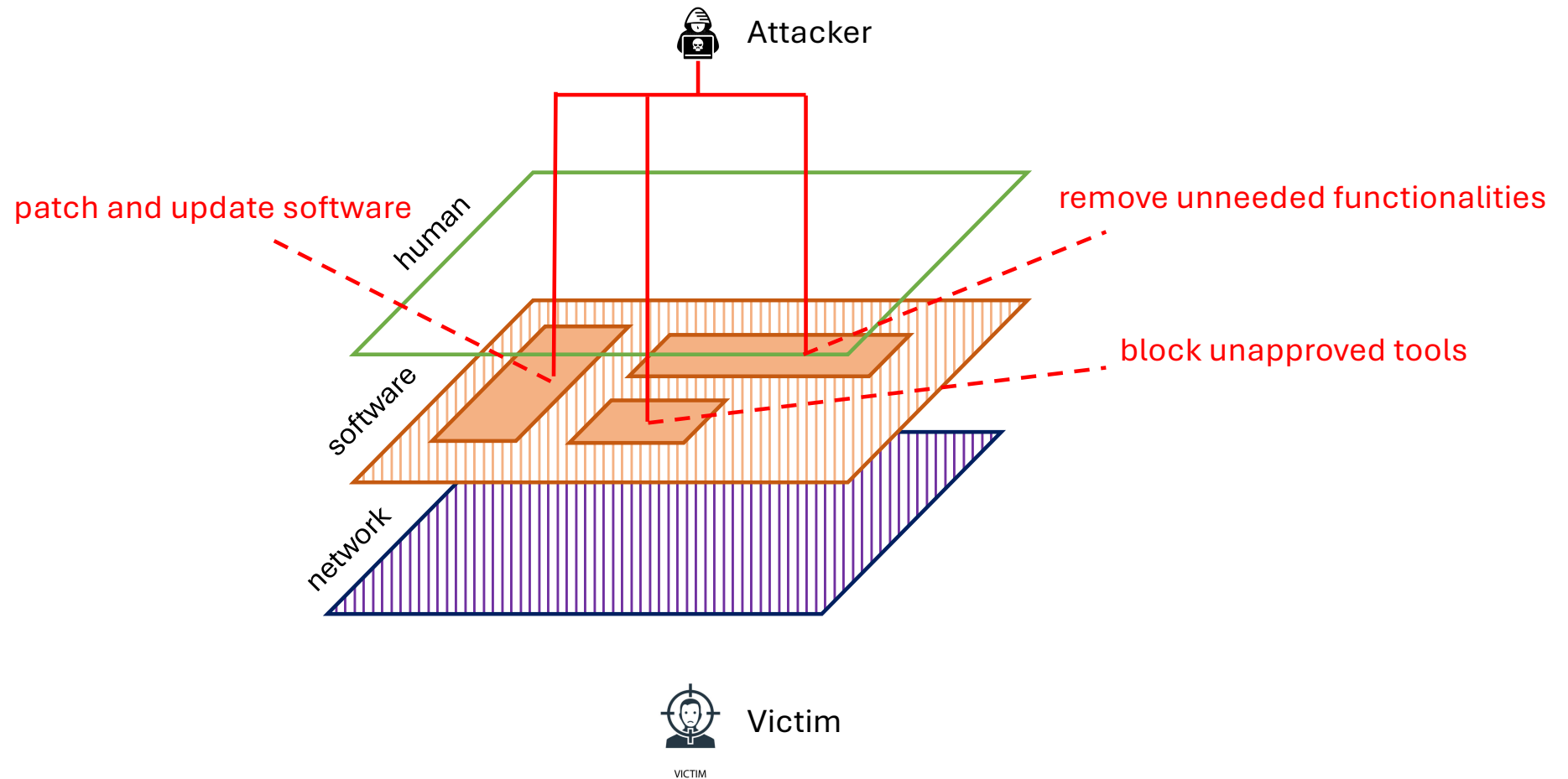


Attack Surface Reduction

- The **attack surface reduction** is the process of minimizing:
 - potential entry points
 - vulnerabilities
 - chances of attacking a system/network.
- Possible strategies:
 - **Reduce complexity**: disable unnecessary or unused software and devices and reduce the number of endpoints being involved
 - **Patch and update**: regularly update all software, hardware and firmware to fix known vulnerabilities and prevent their exploitation
 - **Perform tests**: perform periodically vulnerability scans, penetration tests, and security audits to identify and fix potential weaknesses.



Attack Surface Reduction

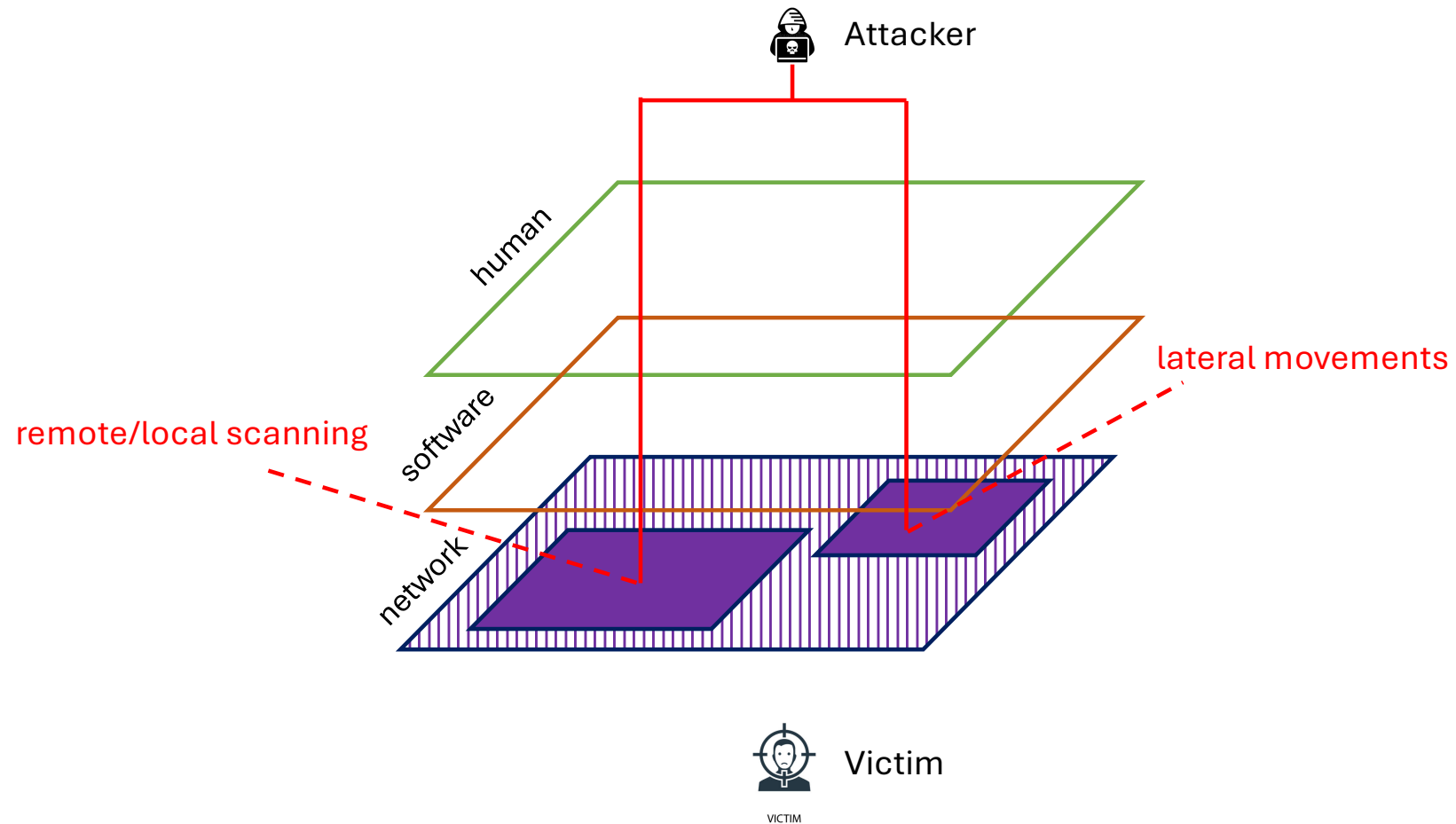


Attack Surface Reduction

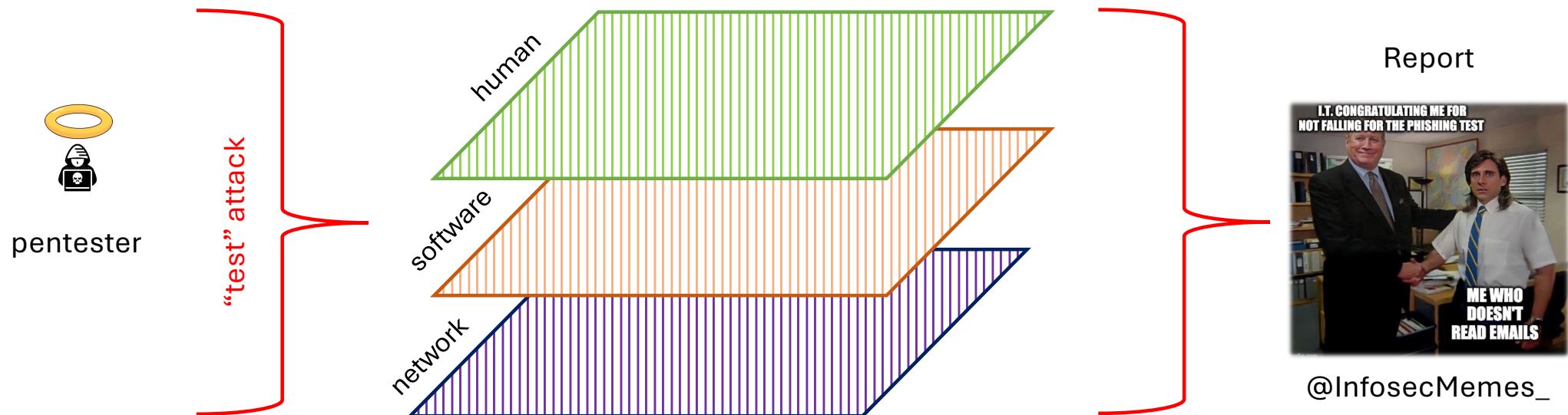
- The **attack surface reduction** is the process of minimizing:
 - potential entry points
 - vulnerabilities
 - chances of attacking a system/network.
- Possible strategies:
 - **Segment network**: divide the network into smaller, isolated segments to contain impacts of potential attacks
 - **Patch and update**: regularly update all nodes or appliances to fix known vulnerabilities and prevent their exploitation
 - **Perform tests**: perform periodically vulnerability scans, penetration tests, and security audits to identify and fix potential weaknesses.



Attack Surface Reduction



Attack Surface Reduction



Possible Vulnerabilities

- Vulnerability:
 - a flaw or weakness in an information system or system security procedures that could be exploited for violating a security policy.
- Examples of **vulnerabilities** by “**nature**”:
 - **unintentional**: bugs
 - **intentional**: backdoors.
- Examples of **vulnerabilities** by **domain**:
 - **technology**: flawed designs or specifications and software/hardware implementations
 - **operation** and **management**: inadequacy of detection approaches or ineffective practices and tools
 - **human**: bad behaviors or permeability to psychological manipulation (e.g., social engineering).

Possible Vulnerabilities

- Vulnerability:
 - a flaw or weakness in an information system or system security procedures that could be exploited for violating a security policy.
- Examples of **network** and **protocol vulnerabilities**:
 - protocol specification flaws
 - protocol implementation flaws
 - misuses: abuse of dynamic configuration protocol or unsecure communications.
- Examples of **software** and **hardware vulnerabilities**:
 - implementation flaws
 - OS flaws
 - hardware flaws.

Question Time



How to quantify the “strength” of an encryption algorithm?

nWEOJ90QeSlg518Klh+9Y3YEw6Rj/psl/Si2i13SXu2hd/8ZRU
wjAllcMbnSjFILj0GX86dNKud8OxYhtSb9CLZf3e5v4fg+DT+F
zoLKpNoeNetCLVbC+txAj5QFCYSV3kkcTSa63RWHNN1mzn
Z/qAVGGVNtPN3gpLEYQZWikfkDXIOlhEGUnGiN2X1kwPeC
UV+ZDySVLaIN4GoqKFletZYnrmmtXKh0xEjJUQxzc9RUbsaJ
cnw3quGRlPk0eXE2

(*)

(*) Leslie Edward Claypool, detto Les (Richmond, 29 settembre 1963), è un bassista, cantante e compositore statunitense, membro fondatore e leader del gruppo alternative metal Primus.

Question Time



How to quantify the “strength” of an encryption algorithm?

```
nWEOJ90QeSlg518Klh+9Y3YEw6Rj/psl/Si2i13SXu2hd/8ZRU  
wjAllcMbnSjFILj0GX86dNKud8OxYhtSb9CLZf3e5v4fg+DT+F  
zoLKpNoeNetCLVbC+txAj5QFCYSV3kkcTSa63RWHNN1mzn  
Z/qAVGGVNtPN3gpLEYQZWikfkDXIOlhEGUnGiN2X1kwPeC  
UV+ZDySVLaIN4GoqKFletZYnrmmtXKh0xEjJUQxzzq9RUbsaJ  
cnw3quGRlPk0eXE2
```

(*)

Possible factors to consider: the length of the key, the availability of plaintext, the “complexity” of the used algorithm, and the required/available computational resources.

(*) Leslie Edward Claypool, detto Les (Richmond, 29 settembre 1963), è un bassista, cantante e compositore statunitense, membro fondatore e leader del gruppo alternative metal Primus.

```
-----  
| AES: CBC, PKCS5 Padding, no IV, |  
| Secret Key: 2312896327181234 |  
-----
```

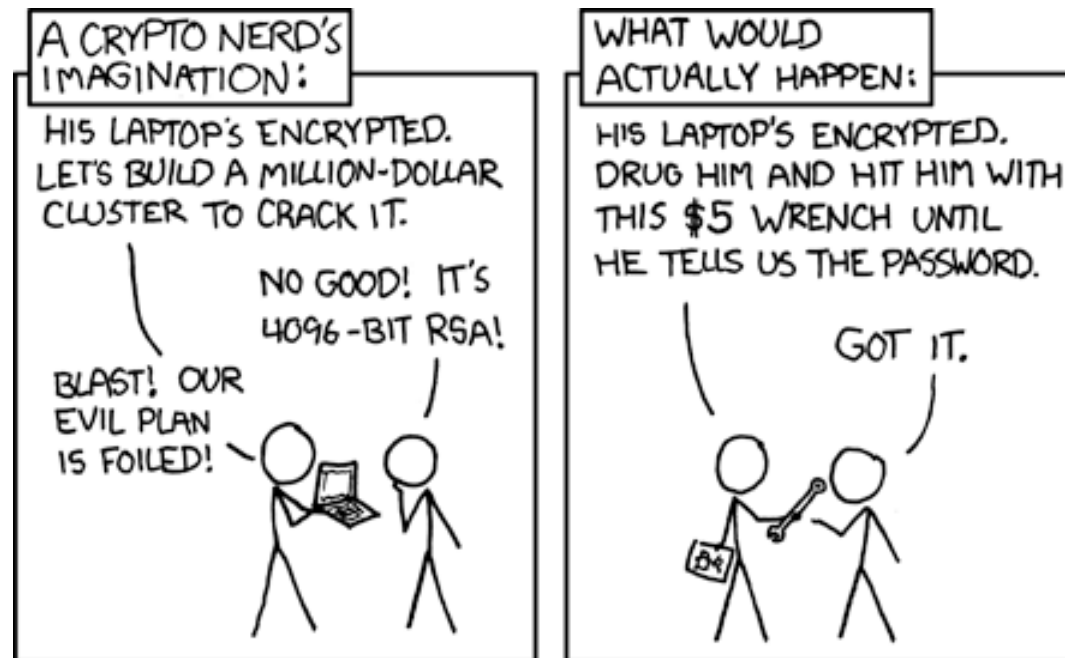
The Human Element

- *Rubber-hose cryptanalysis*, Marcus J. Ranum, 1990.



The Human Element

- *Rubber-hose cryptanalysis*, Marcus J. Ranum, 1990.



Source: XKCD



The Human Element



Source: AZ Quotes

Question Time



What is wrong?

Q	w	e	r	t	y	u	i	o
---	---	---	---	---	---	---	---	---

1	2	3	q	w	e
---	---	---	---	---	---

1	q	2	w	3	e	4	r
---	---	---	---	---	---	---	---

Question Time



- These passwords are:
 - predictable
 - easy to guess
 - easy to generate via software
 - **patterns!**

Q	w	e	r	t	y	u	i	o
1	2	3	q	w	e			
1	q	2	w	3	e	4	r	

The Human Element



- These passwords are:
 - predictable
 - easy to guess
 - easy to generate via software
 - **patterns!**

Q	w	e	r	t	y	u	i	o
1	2	3	q	w	e			
1	q	2	w	3	e	4	r	

Dig: Jonh The Ripper (<https://github.com/openwall/john>)

Dictionaries are quite easy to prepare and “wallow” in social engineering!



The Human Element



- These passwords are:
 - predictable
 - easy to guess
 - easy to generate via software
 - **patterns!**

Q	w	e	r	t	y	u	i	o
1	2	3	q	w	e			
1	q	2	w	3	e	4	r	

Dig: Jonh The Ripper (<https://github.com/openwall/john>)

<https://github.com/ihebski/DefaultCreds-cheat-sheet>



Very easy to **automate** the **search** for **default credentials** or the creation of **mutations**!

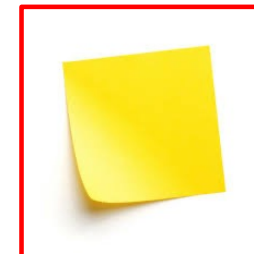
The Human Element



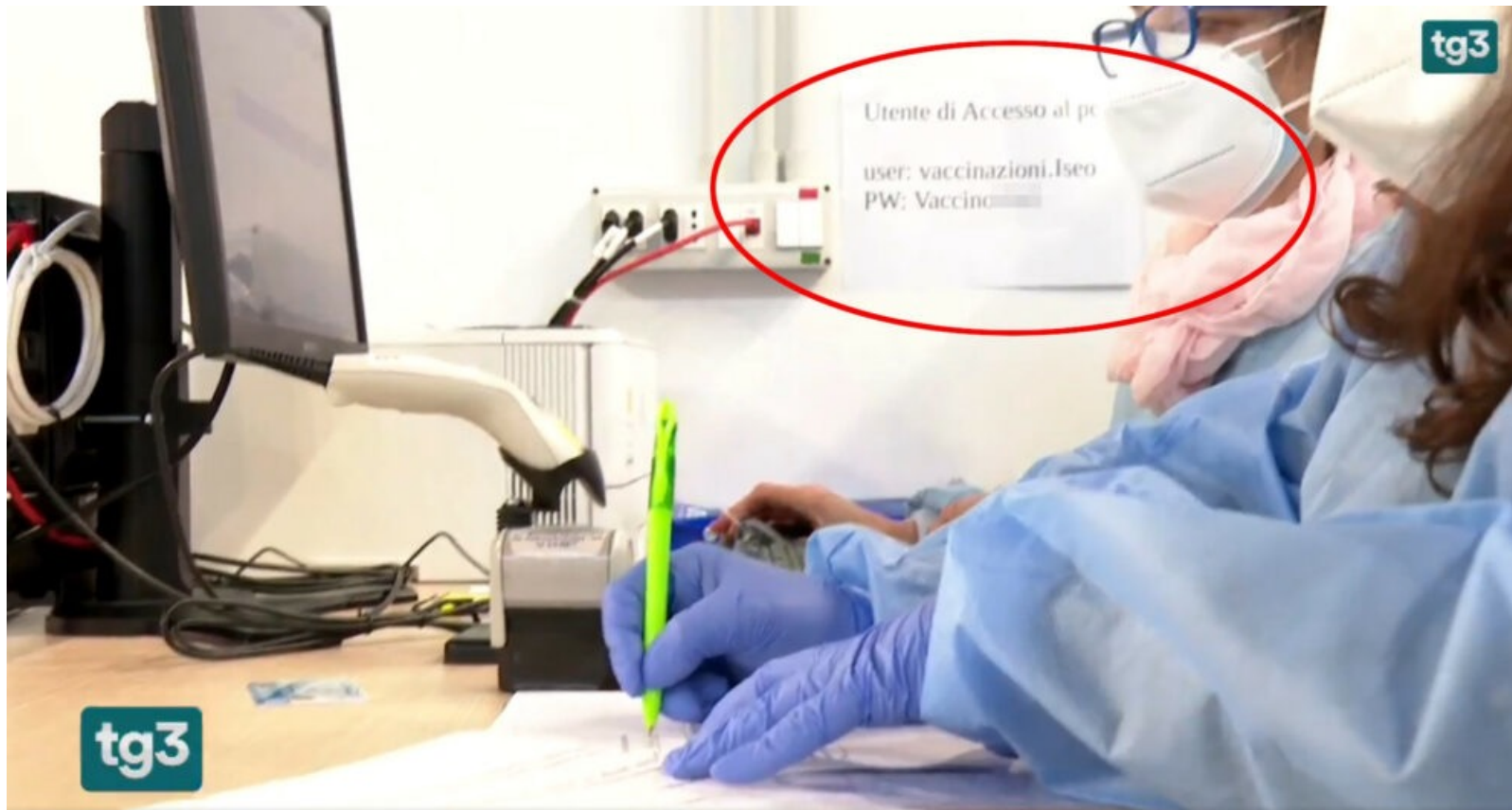
- These passwords are:
 - predictable
 - easy to guess
 - easy to generate via software
 - **patterns!**

Q	w	e	r	t	y	u	i	o
1	2	3	q	w	e			
1	q	2	w	3	e	4	r	

It would be better to use something more complicated, being careful not to ruin the attempt.



...a Dramatic Turn of Events



Source: TG3 of 6 March 2021.

Vaccination Hub in Brescia, Italy

AI Amplifies Human Vulnerabilities

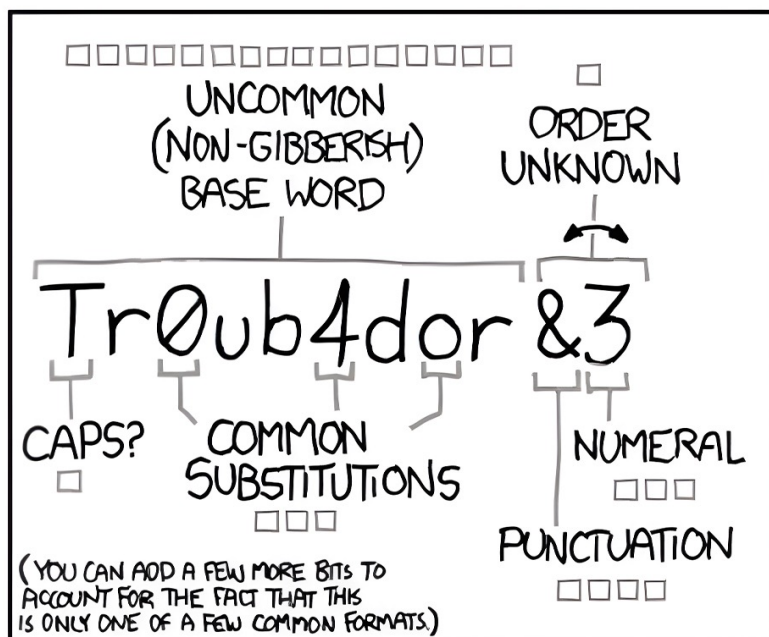
- It is now well established that AI:
 - can **lower** the barrier for preparing **social-engineering** attacks
 - is causing a paradigm shift in **information disorder**
 - transformed **phishing** campaigns.
- Some examples on the use of LLMs(*):
 - **personalized spear phishing**: Emerald Sleet (North Korea) used LLMs to identify relevant experts and draft targeted phishing content tailored to individual victims
 - **more credible pretexts**: Crimson Sandstorm (Iran) used LLMs to create phishing emails impersonating trusted organizations and targeting specific social groups
 - **removed language barriers**: Charcoal Typhoon (China) used LLM-assisted translation and communication to build trust and manipulate targets across different languages.



Source: Trustedsec

(*) <https://www.microsoft.com/en-us/security/blog/2024/02/14/staying-ahead-of-threat-actors-in-the-age-of-ai>

The Final Recap on the “Human Element”



THROUGH 20 YEARS OF EFFORT, WE'VE SUCCESSFULLY TRAINED EVERYONE TO USE PASSWORDS THAT ARE HARD FOR HUMANS TO REMEMBER, BUT EASY FOR COMPUTERS TO GUESS.

Source: XKCD

It is **very hard** to **protect** or **reduce** an attack surface when “stupid” things are done by **humans**. And poor management of credentials and passwords are just the **tip of the iceberg!**

AI is creating **new attack vectors** or **revamping** old ones. It is important to prevent the **weaponization** of information, e.g., by limiting public details about employees, organizational structures, suppliers, and internal processes.

Humans should then be **trained** to recognize AI, for instance by identify unusual requests, urgency, tones, or deviations from established procedures. AI-based threats transform the user into a **human-in-the-loop attack vector** rather than the human as the **last line of defense**.

Wrap Up

- Cybersecurity has a huge **impact** on our **society**, also in terms of **economical losses** and **socio-political implications**.
- **Everyone** has a **responsibility** in the overall security posture!
- Prime **conceptual frameworks** to describe a cyber attacks are the **Cyber Kill Chain**, the **MITRE ATT&CK**, and **attack trees**.
- It is vital being able to **outline** and **recognize attack surfaces**, which are different and composite.
- A relevant amount of the cybersecurity **routine** is to operate in an **attack surface reduction flavor**.
- **...but the human element will always play a major role.**